16/10/26

Informe de seguridad ofensiva

Andrea Morúa Bravo

Seguridad Informática

MTRO. SERVANDO LÓPEZ CONTRERAS

Contenido

Alcance y metodología 5
Resumen ejecutivo 5
Inventario de vulnerabilidades 6
Descripción de los retos: 8
Reto 01: Exposición de archivos en el directorio raíz 8
Descripción técnica y causa raíz: 8
Comprobación de los hallazgos: 9
Evidencia técnica: 9
Impacto y riesgo: 10
Mitigaciones: 10
Reto 02: Información sensible en recursos del cliente (archivos js) 10
Descripción técnica y causa raíz: 10
Comprobación de los hallazgos: 10
Evidencia técnica: 10
Impacto y riesgo: 12
Mitigaciones: 12
Reto 03: Control de acceso a objetos por referencias directas inseguras (idor) 12
Descripción técnica y causa raíz: 12
Comprobación de los hallazgos: 13
Evidencia técnica: 13
Impacto y riesgo: 13
Mitigaciones: 14
Reto 04: Exposición de archivos de respaldo histórico (.bak) 14
Descripción técnica y causa raíz: 14
Comprobación de los hallazgos: 14
Evidencia técnica: 14
Impacto y riesgo**:** 15
Mitigaciones: 15
Reto 05: Divulgación de información mediante errores no gestionados 15
Descripción técnica y causa raíz: 15
Comprobación de los hallazgos: 16

Evidencia técnica: 16
Impacto y riesgo: 17
Mitigaciones: 17
Reto 06: Control de acceso basado en rol deficiente (manipulación en el cliente) 17
Descripción técnica y causa raíz: 17
Comprobación de los hallazgos: 18
Evidencia técnica: 18
Impacto y riesgo: 20
Mitigaciones: 20
Reto 07: Inyección SQL Ciega Basada en Inferencia (Blind Boolean) 20
Descripción técnica y causa raíz: 20
Comprobación de los hallazgos: 21
Evidencia técnica: 21
Impacto y riesgo: 22
Mitigaciones: 22
Reto 08: Inyección de contenido persistente (stored xss) 22
Descripción técnica y causa raíz: 22
Comprobación de los hallazgos: 23
Evidencia técnica: 23
Impacto y riesgo: 24
Mitigaciones: 25
Reto 09: Acceso a Rutas Fuera del Directorio Autorizado (Path Traversal) 25
Descripción técnica y causa raíz: 25
Comprobación de los hallazgos: 25
Evidencia técnica: 25
Impacto y riesgo: 26
Mitigaciones: 26
Reto 10: Reutilización de sesión débil (falta de invalidación post-login) 26
Descripción técnica y causa raíz: 26
Comprobación de los hallazgos: 27
Evidencia técnica: 27
Impacto y riesgo: 29

Mitigaciones: 29
Reto 11: Descubrimiento de endpoint de api no documentado 29
Descripción técnica y causa raíz: 29
Comprobación de los hallazgos: 29
Evidencia técnica: 29
Impacto y riesgo: 31
Mitigaciones: 31
Reto 12: Autorización de Objetos Deficiente en API (BCO / IDOR en API) 31
Descripción técnica y causa raíz: 31
Comprobación de los hallazgos: 32
Evidencia técnica: 32
Impacto y riesgo: 32
Mitigaciones: 33
Reto 13: Abuso de lógica de negocio en flujo de pagos 33
Descripción técnica y causa raíz: 33
Comprobación de los hallazgos: 33
Evidencia técnica: 33
Impacto y riesgo: 34
Mitigaciones: 35
Reto 14: Validación deficiente de relaciones entidad contrato-proveedor 35
Descripción técnica y causa raíz: 35
Comprobación de los hallazgos: 35
Evidencia técnica: 35
Impacto y riesgo: 36
Mitigaciones: 36
Reto 15: Divulgación de arquitectura interna en metadatos de diagnóstico 36
Descripción técnica y causa raíz: 36
Comprobación de los hallazgos: 36
Evidencia técnica: 36
Impacto y riesgo: 38
Mitigaciones: 38
Reto 16: acceso indebido al gateway mediante suplantación de origen (ip/policy spoofing) 38

Descripción técnica y causa raíz: 38
Comprobación de los hallazgos: 38
Evidencia técnica: 39
Impacto y riesgo: 40
Mitigaciones: 40
Reto 17: Acceso no autorizado a vistas operacionales hmi y telemetría 40
Descripción técnica y causa raíz: 40
Comprobación de los hallazgos: 40
Evidencia técnica: 40
Impacto y riesgo: 42
Mitigaciones: 42
Reto 18: validación defectuosa de actualización de firmware simulado (fuerza bruta de hash) 42
Descripción técnica y causa raíz: 42
Comprobación de los hallazgos: 43
Evidencia técnica: 43
Impacto y riesgo: 47
Mitigaciones: 47
Reto 19: Encadenamiento de hallazgos it-ot (cadena de dependencias hmi) 47
Descripción técnica y causa raíz: 47
Comprobación de los hallazgos: 48
Evidencia técnica: 48
Impacto y riesgo: 49
Mitigaciones: 49
Reto 20: Impacto operacional completo en automatización simulada (la bandera final) 49
Descripción técnica y causa raíz: 49
Comprobación de los hallazgos: 50
Evidencia técnica: 50
Impacto y riesgo: 52
Mitigaciones: 52
Cadena de ataque consolidada 52
Fase 1: Reconocimiento y exposición inicial 52

Fase 2: Escalamiento y extracción de datos web 52
Fase 3: Transición y salto de frontera ITI-OT 52
Fase 4: Compromiso del centro de operaciones y automatización (OT) 53

Alcance y metodología

Objetivo: Evaluar la postura de seguridad defensiva y ofensiva de los portales web, APIs, componentes de red y sistemas de automatización industrial simulados (INTERAFAS / entorno local y de laboratorio en localhost:8080), identificando vulnerabilidades críticas en el ciclo de despliegue, control de acceso, gestión de sesiones y la infraestructura TI-OT.

Alcance del entorno:

- Aplicación web corporativa y Portal Ciudadano (INTERAFAS).
- Módulos de transparencia, contratación, gestión de proveedores y centro de operaciones HMI (/operations/).
- Entornos de servicios expuestos y endpoints de API internos/no documentados.

Metodología de evaluación: Basada en estándares internacionales de pruebas de penetración y análisis de vulnerabilidades web y de infraestructura (OWASP WSTG - Web Security Testing Guide, OWASP API Security Top 10 y pruebas de seguridad de sistemas de control industrial/OT y Portswigger).

Reglas del ejercicio y limitaciones: Pruebas controladas ejecutadas de forma local y contra los objetivos autorizados del laboratorio de seguridad, empleando herramientas como navegador web con herramientas de desarrollo (DevTools), Burp Suite Community Edition, gobuster, nikto, sqlmap, hashcat y utilidades de línea de comandos en entorno Linux (Kali).

Resumen ejecutivo

Durante la auditoría de seguridad ofensiva realizada al ecosistema tecnológico de INTERAFAS en el entorno de pruebas (localhost:8080), se identificaron y comprobaron un total de 20 vulnerabilidades críticas y banderas de validación, abarcando desde la exposición de archivos de configuración residuales en el directorio raíz hasta vulnerabilidades severas de control de acceso horizontal y vertical (IDOR), Inyección SQL ciega basada en inferencia, ejecución de código del lado del cliente (Stored XSS), Path Traversal y fallas graves en la integración de arquitecturas IT-OT (puentes operacionales y validación de firmware HMI).

La evolución del incidente demostró que una combinación de errores de configuración en despliegue, falta de sanitización de entradas, confianza excesiva en datos controlados por el cliente (como cookies de rol y cabeceras de red) y debilidades lógicas en flujos de pago y validación de proveedores, permite a un atacante escalar privilegios desde una sesión ciudadana anónima o de bajo privilegio hasta el control completo de los componentes HMI y de automatización industrial simulada. Se requiere un plan de mitigación inmediato enfocado en endurecer la directriz de despliegue, implementar controles robustos de autorización basada en servidor y aplicar principios de mínimo privilegio en todas las capas.

Inventario de vulnerabilidades

ID	Vulnerabilidad	Componente Afectado	Categoría	Bandera
V01	Exposición de archivo de configuración en despliegue.	En él .ZIP, Deploy > release-check.env	Exposición de información	UPSLP_CNOIV-OPEN-DOOR-01
V02	Informacion sensible en metadatos y recursos del cliente.	/assets/meta/build-manifest.php	Reconocimiento / Divulgación de información	UPSLP_CNOIV-LOOK-CLOSER-02
V03	Control de acceso a objetos por referencias directas inseguras (IDOR).	/expediente.php?id=	Autorización / IDOR	UPSLP_CNOIV-NOT-YOURS-03
V04	Archivo de respaldo histórico expuesto.	Transparencia.php.bak	Exposición de respaldos	UPSLP_CNOIV-OLD-MEMORIES-04
V05	Divulgación de información mediante errores no gestionados.	/proveedores.php	Divulgación mediante errores	UPSLP_CNOIV-TOO-MUCH-INFO-05
V06	Control de acceso basado en rol deficiente	Cookie portal role	Control de acceso/Escalamiento vertical	UPSLP_CNOIV-WRONG-ROLE-06

V07	Inyección SQL ciega basada en inferencia	/validar-referencia.php?ref=	Inyección SQL (Blind Boolean-based)	UPSLP_CNOIV-SILENT-ANSWER-07
V08	Inyección de contenido persistente (Stored XSS)	/reportes.php en su formulario	Cliente / Cross-Site Scripting Persistente	UPSLP_CNOIV-STORED-WORDS-08
V09	Acceso a rutas fuera del directorio autorizado (Path Traversal)	/descargar-documento.php?file=	Archivos/Path Traversal	UPSLP_CNOIV-TOO-DEEP-09
V10	Reutilización de sesión débil (Falta de invalidación post-login)	PHPSESSID	Gestión débil de sesión	UPSLP_CNOIV-WHO-ARE-YOU-10
V11	Descubrimiento de endpoint de API no documentado	/api/service-history.php	API / Endpoint oculto	UPSLP_CNOIV-HIDDEN-HISTORY-11
V12	Autorización de objetos deficiente en API (Bypassing object ownership)	/api/service-history.php?account=	API / Autorización horizontal	UPSLP_CNOIV-SECOND-ACCOUNT-12
V13	Abuso de lógica de negocio en flujo de pago	/pago.php?factura=	Lógica de negocio / Manipulación de montos	UPSLP_CNOIV-PAYMENT-PATH-13
V14	Validación deficiente de relaciones entidad contrato-proveedor	/validar-vinculo-contractual.php	Lógica de negocio / Inconsistencia relacional	UPSLP_CNOIV-TRUSTED-SUPPLIER-14
V15	Divulgación de arquitectura interna en metadatos de diagnóstico	/api/infrastructure-status.php	Arquitectura / Información interna	UPSLP_CNOIV-BEHIND-THE-DESK-15

V16	Acceso indebido al gateway mediante suplantación de origen (IP/Policy spoofing)	/operations/gateway.php	IT-OT / Control de acceso perimetral	UPSLP_CNOIV-BEYOND-THE-WEB-16
V17	Acceso no autorizado a vistas operacionales HMI y telemetría	/operations/telemetry.php	OT sim / Exposición de telemetría	UPSLP_CNOIV-EYES-ON-THE-PLANT-17
V18	Validación defectuosa de actualización de firmware simulado	/operations/updates/install.php	Firmware sim / Fuerza bruta de hash	UPSLP_CNOIV-TRUST-THE-PACKAGE-18
V19	Encadenamiento de hallazgos IT-OT (Exceso de privilegios en rol maintenance)	/operations/#assets	Cadena de ataque IT-OT	UPSLP_CNOIV-CHAIN-REACTION-19
V20	Impacto operacional completo en automatización simulada	/operations/firmware.php	OT sim / Integridad de procesos	UPSLP_CNOIV-NOW-YOU-CONTROL-20

Descripción de los retos:

Reto 01: Exposición de archivos en el directorio raíz

Descripción técnica y causa raíz:

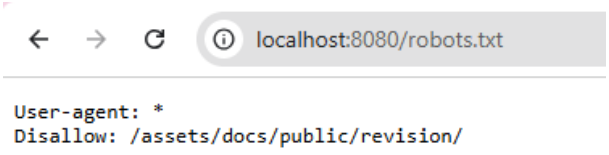
El servidor web expone un archivo robots.txt que indica a los motores de búsqueda las rutas que no deben rastrear. No obstante, al analizar el archivo se identificó que ocultaba el directorio /assets/docs/public/revision/, el cual permitía la indexación y exploración de directorios de Apache. La causa raíz radica en la inclusión de archivos de despliegue (.zip) en rutas accesibles públicamente bajo el document root sin restricciones de permisos.

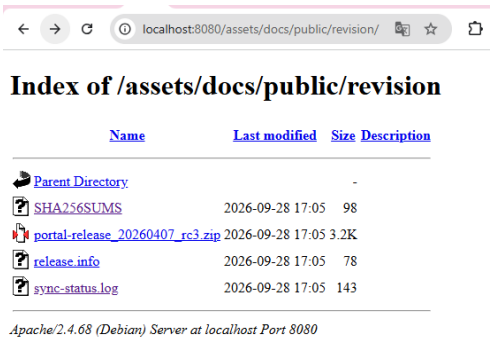
Comprobación de los hallazgos:

1. Se examinó el archivo público http://localhost:8080/robots.txt desde el navegador.
2. Se identificó la directiva de exclusión Disallow: /assets/docs/public/revision/.
3. Se navegó directamente a dicha ruta, descubriendo un directorio expuesto con listado habilitado (Directory Listing).
4. Se descargó el archivo comprimido de despliegue portal-release_20260407_rc3.zip.
5. Se descomprimió el archivo y se localizó en la carpeta deploy el archivo release-check.env, el cual contenía el token de verificación SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01.

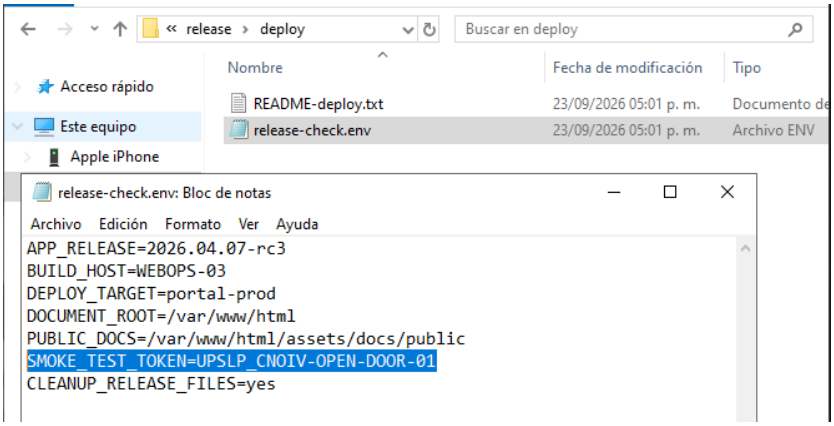
Evidencia técnica:

Archivo robots.txt: Disallow: /assets/docs/public/revision/





Archivo de configuración encontrado en deploy/release-check.env:
SMOKE_TEST_TOKEN=UPSLP_CNOIV-OPEN-DOOR-01



Impacto y riesgo:

Nivel de impacto: Medio/Alto

Confidencialidad: Alta

Integridad/Disponibilidad: Baja

Exposición de variables de entorno, nombres de hosts internos de despliegue y credenciales o tokens de prueba que facilitan el reconocimiento temprano de la infraestructura.

Mitigaciones:

Eliminar todos los archivos de respaldo y compendios de despliegue (.zip, .env) de los directorios accesibles por el servidor web; configurar el servidor Apache para deshabilitar la directiva Indexes (Directory Listing).

Reto 02: Información sensible en recursos del cliente (archivos js)

Descripción técnica y causa raíz:

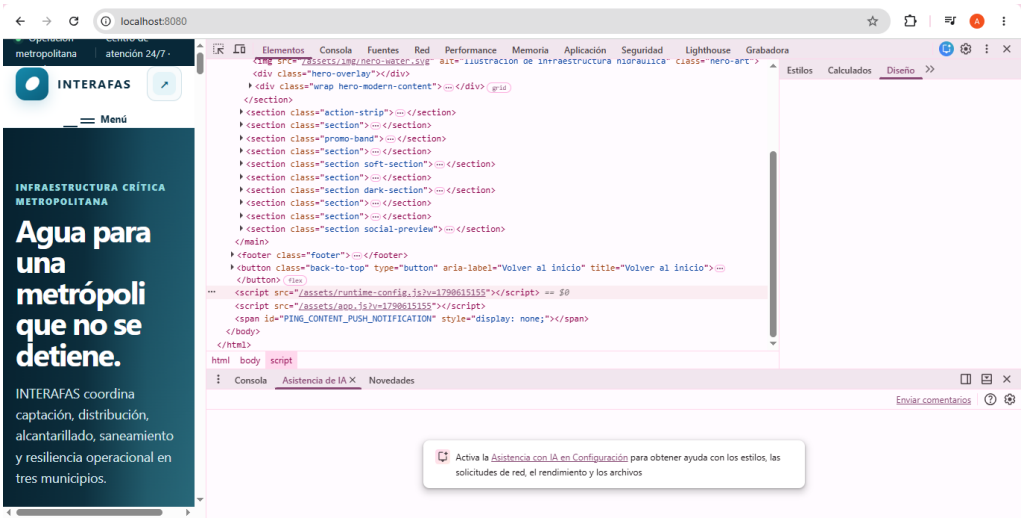
La aplicación expone en el código fuente de la página principal referencias a scripts de JavaScript (/assets/runtime-config.js) que contienen configuraciones de ejecución del entorno, release, y puntos de enlace de APIs y manifiestos de compilación. La causa raíz es la inclusión de metadatos internos de compilación en el código de lado del cliente sin sanitización.

Comprobación de los hallazgos:

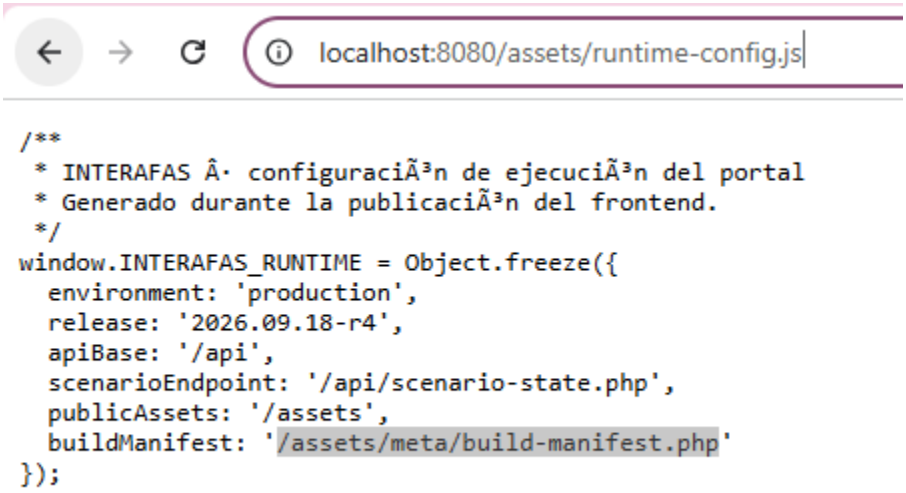
1. Se inspeccionó el código fuente de la página principal (http://localhost:8080/) y se examinó el tráfico de red mediante las herramientas de desarrollo (*DevTools -> Network*).
2. Se localizó la inclusión del script de configuración en tiempo de ejecución (/assets/runtime-config.js).
3. Se accedió directamente a dicho script, extrayendo la ruta interna hacia el manifiesto de compilación (buildManifest: '/assets/meta/build-manifest.php').
4. Al consultar la ruta del manifiesto, se obtuvo la versión del release y la segunda bandera de validación.

Evidencia técnica:

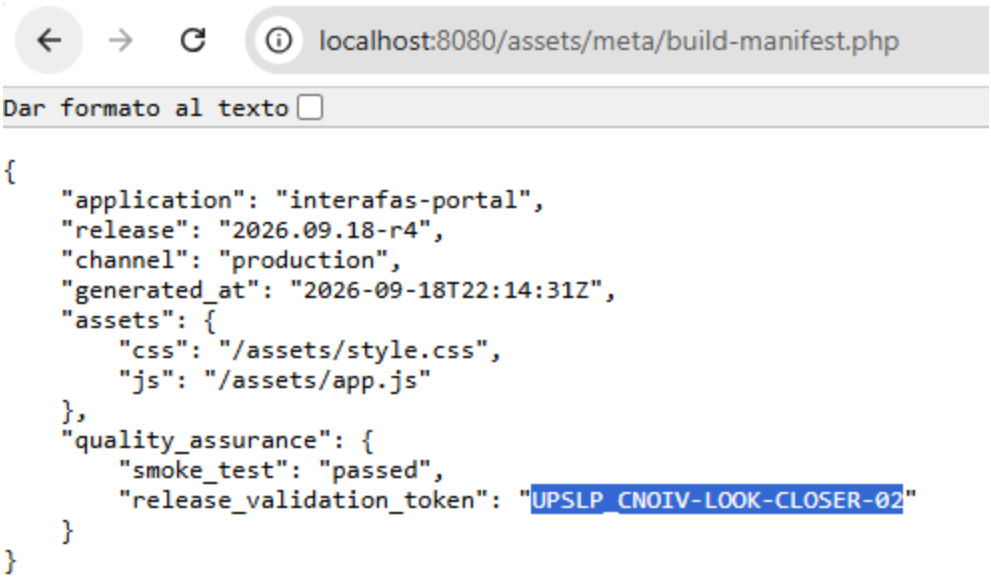
Inspección de ruta: localhost:8080/



Ruta del script: /assets/runtime-config.js



Archivo: /assets/meta/build-manifest.php



Contenido de validación: "release_validation_token": "UPSLP_CNOIV-LOOK-CLOSER-02"

Impacto y riesgo:

Nivel de impacto: Bajo / Medio

Confidencialidad: Media

Integridad/Disponibilidad: Baja.

Revelación de la arquitectura interna de versiones y rutas de control de calidad, facilitando a un atacante conocer los canales de producción y endpoints de depuración.

Mitigaciones:

Ocultar los metadatos de compilación y control de calidad en entornos de producción, y restringir el acceso a los scripts de configuración interna únicamente a servicios del backend.

Reto 03: Control de acceso a objetos por referencias directas inseguras (idor)

Descripción técnica y causa raíz:

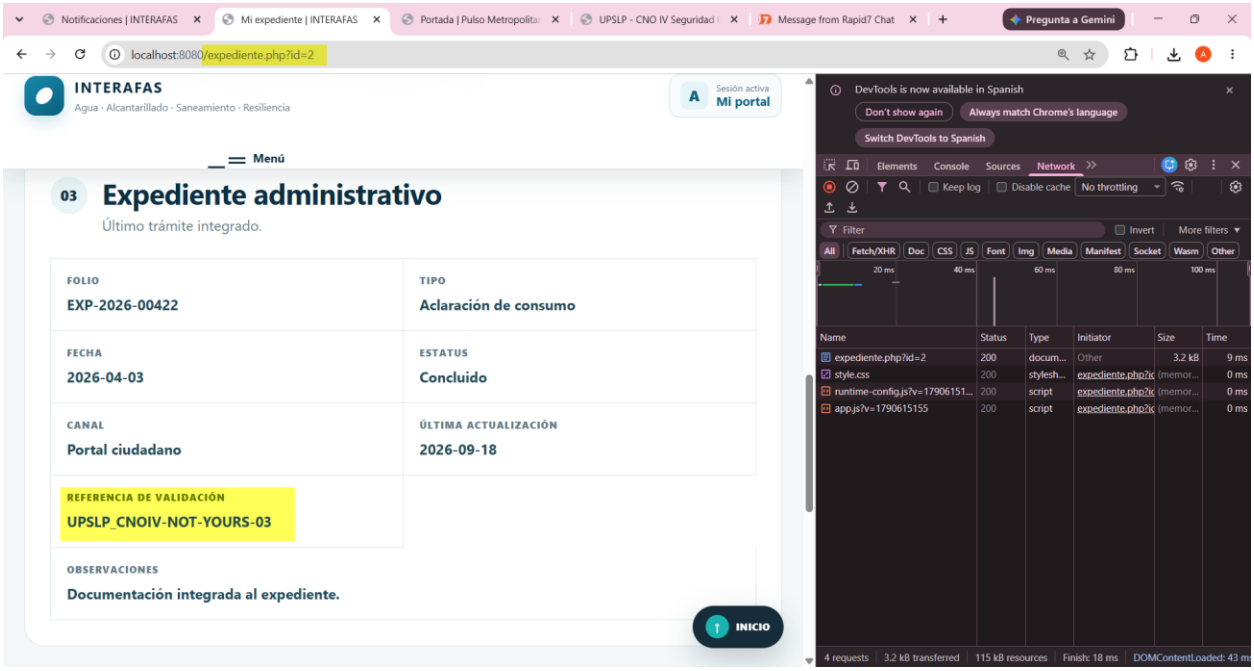
El módulo "Mi expediente" procesa consultas mediante identificadores secuenciales en la URL (expediente.php?id=1). El backend realiza la consulta del recurso sin verificar si el ID del expediente pertenece estrictamente al usuario autenticado en la sesión activa. La causa raíz es la ausencia de validación de autorización a nivel de objeto (BOLA / IDOR).

Comprobación de los hallazgos:

1. Se autenticó en el portal ciudadano con una cuenta propia válida.
2. Se navegó al módulo de consulta de expedientes, generando la petición http://localhost:8080/expediente.php?id=1.
3. Se modificó manualmente el parámetro numérico en la URL a id=2.
4. Se comprobó que el backend procesó la solicitud y devolvió el expediente administrativo, folio y referencia de validación correspondientes a otro ciudadano sin validar la titularidad.

Evidencia técnica:

URL evaluada: http://localhost:8080/expediente.php?id=2



Referencia de validación mostrada: UPSLP_CNOIV-NOT-YOURS-03

Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad: Alta

Integridad: Media.

Disponibilidad: Baja.

Exposición masiva de datos personales, expedientes administrativos, folios y estados de cuenta de terceros a cualquier usuario autenticado.

Mitigaciones:

Implementar controles de control de acceso basados en la sesión (verificando que el ID del recurso consultado pertenezca al ID del usuario autenticado en la base de datos).

Reto 04: Exposición de archivos de respaldo histórico (.bak)

Descripción técnica y causa raíz:

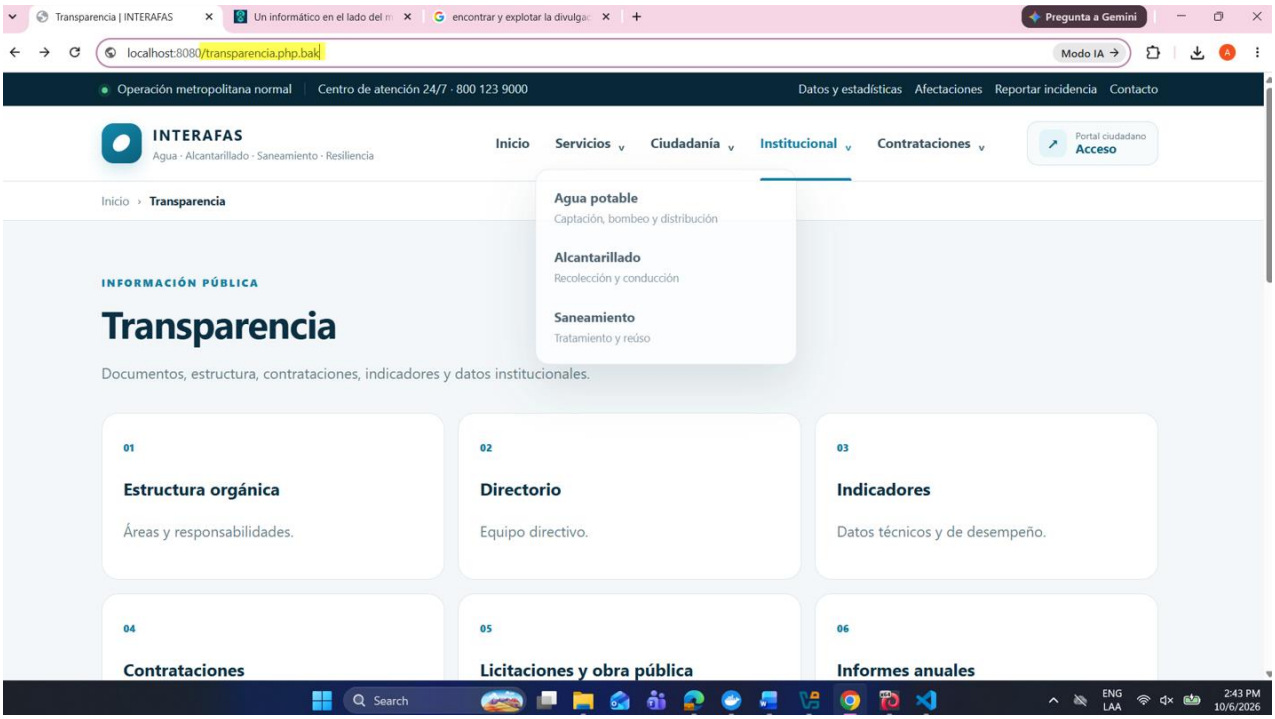
Copias de seguridad de archivos fuente PHP (transparencia.php.bak) fueron dejadas en el servidor web bajo el document root. Dado que el servidor web no interpreta la extensión .bak como script PHP, el código fuente plano es devuelto directamente al cliente. La causa raíz fue el incumplimiento de las políticas de limpieza de artefactos tras modificaciones de código.

Comprobación de los hallazgos:

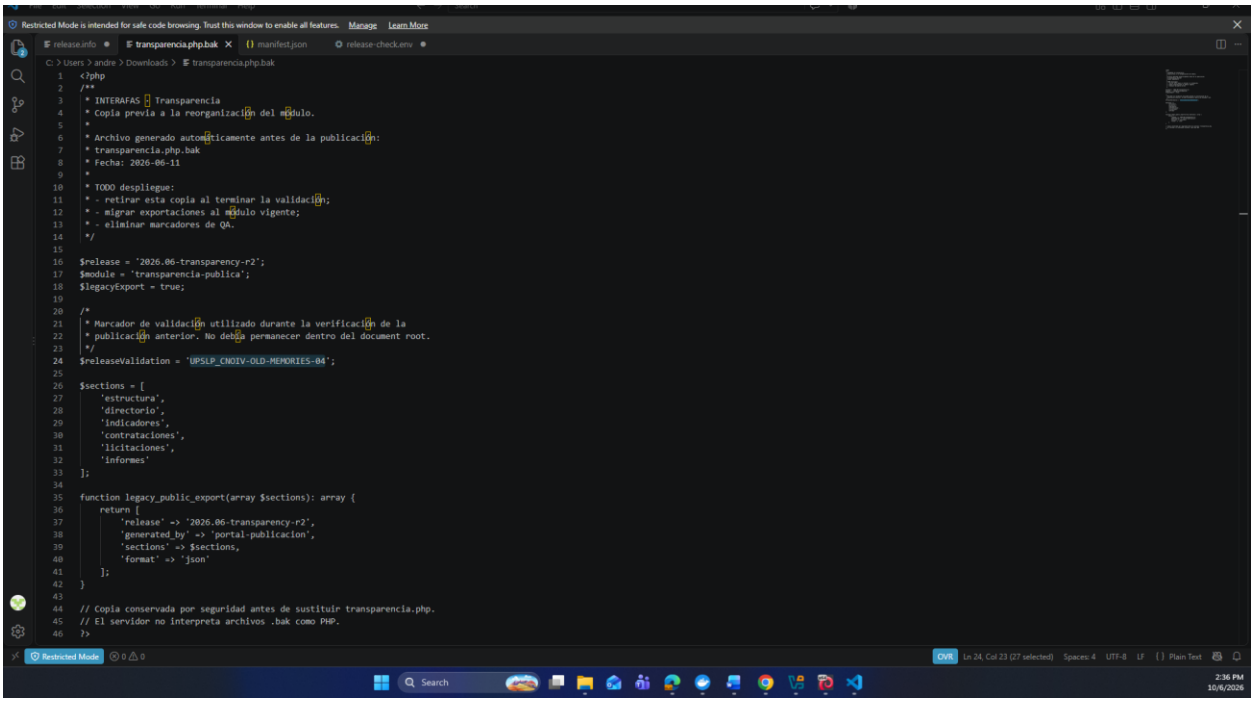
1. Se identificaron las rutas de páginas dinámicas del portal (ej. transparencia.php).
2. Se añadió manualmente la extensión .bak a la URL solicitando http://localhost:8080/transparencia.php.bak.
3. Se observó que el servidor web Apache, al no reconocer la extensión como un script ejecutable PHP, entregó el contenido íntegro del archivo como texto plano.
4. Se examinó el código fuente descargado para revelar la lógica interna de negocio, variables de entorno y la bandera.

Evidencia técnica:

Archivo recuperado: transparencia.php.bak



Variable interna expuesta: $releaseValidation = 'UPSLP_CNOIV-OLD-MEMORIES-04';



Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad: Alta

Integridad/Disponibilidad: Baja

Divulgación total de la lógica de negocio del script, funciones internas, variables de entorno y comentarios de desarrollo que describen parches o modificaciones pendientes.

Mitigaciones:

Automatizar rutinas de limpieza que eliminen archivos temporales o de respaldo con extensiones .bak, .old, .txt o .zip antes de consolidar el despliegue.

Reto 05: Divulgación de información mediante errores no gestionados

Descripción técnica y causa raíz:

La funcionalidad de exportación de datos de proveedores (exportar.php) implementa una estructura de control en PHP (match expression) para procesar el parámetro de entrada. Al recibir un parámetro vacío o no contemplado, la aplicación no define un brazo por defecto (default), generando una excepción no controlada del tipo Unhandled

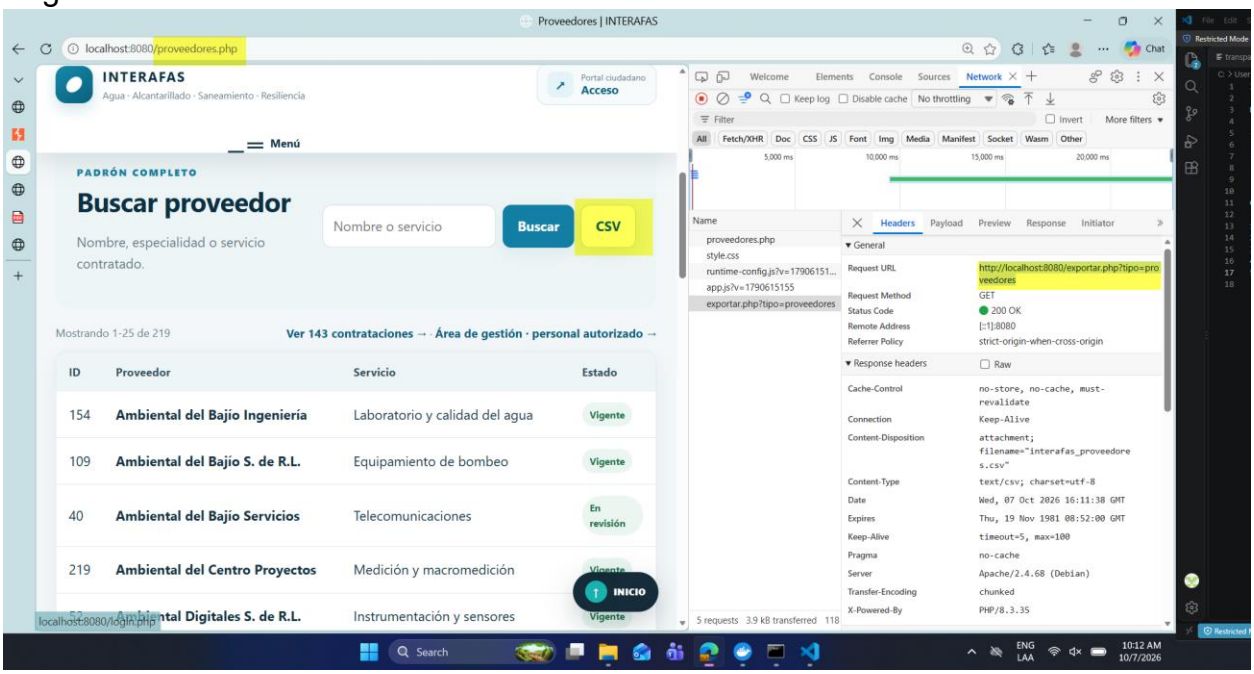
export exception. La causa raíz es el manejo deficiente de excepciones y la habilitación del modo de depuración en producción (DEBUG RESPONSE ENABLED).

Comprobación de los hallazgos:

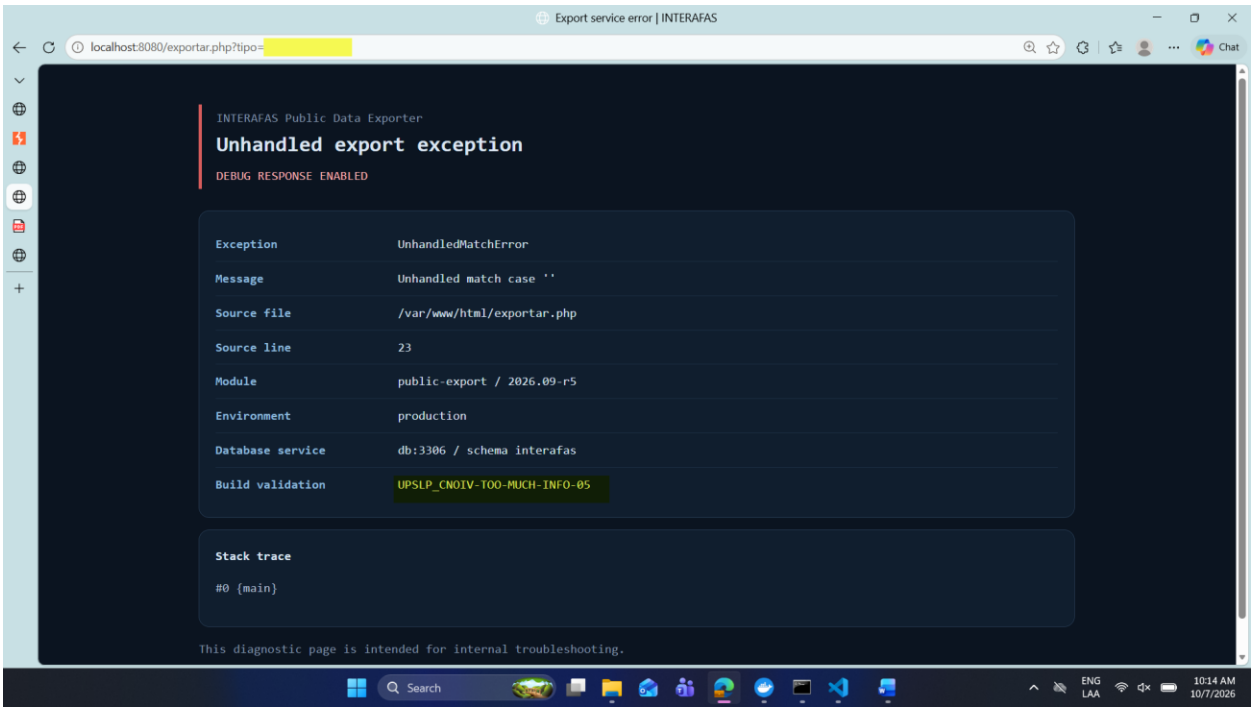
1. Se accedió al módulo de exportación de datos en /exportar.php.
2. Se manipuló el parámetro de entrada enviándolo vacío u omitiéndolo (/exportar.php?tipo=).
3. Se provocó una excepción no controlada (UnhandledMatchError) debido a la ausencia de una rama por defecto (default) en la estructura de control match de PHP.
4. Se analizó la pantalla de diagnóstico obtenida, la cual expuso rutas absolutas del servidor, líneas de código, versiones del módulo y datos de conexión a la base de datos.

Evidencia técnica:

Pagina vulnerable:



Excepción: UnhandledMatchError en /var/www/html/exportar.php (Línea 23)



Build validation / Bandera: UPSLP_CNOIV-TOO-MUCH-INFO-05

Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad: Alta

Integridad/Disponibilidad: Baja.

Revelación de rutas absolutas del servidor, versión del módulo, entorno de ejecución, estructura de la base de datos (db:3306 / schema interafas) y detalles de la pila de llamadas (Stack Trace).

Mitigaciones:

Deshabilitar los mensajes detallados de depuración (stack traces) en entornos de producción y asegurar el manejo robusto de excepciones (bloques try-catch y manejo de casos por defecto en estructuras condicionales).

Reto 06: Control de acceso basado en rol deficiente (manipulación en el cliente)

Descripción técnica y causa raíz:

El sistema gestiona los privilegios de acceso evaluando una cookie almacenada en el navegador (portal_role=citizen). La causa raíz radica en la confianza ciega del backend

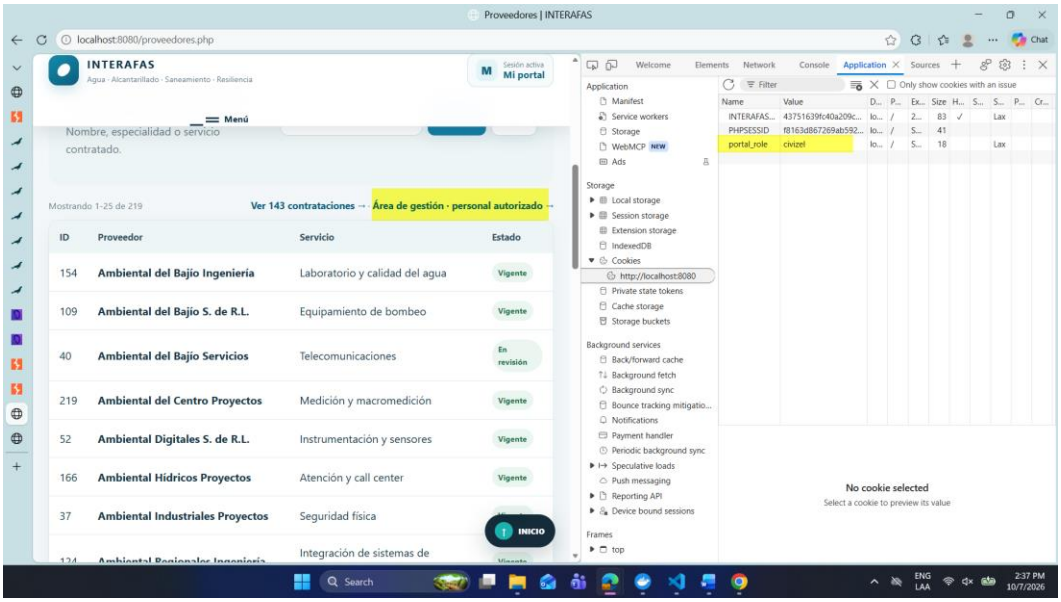
en los datos controlados por el cliente, permitiendo que cualquier usuario altere el valor de la cookie para suplantar roles administrativos (cambiando a procurement_admin).

Comprobación de los hallazgos:

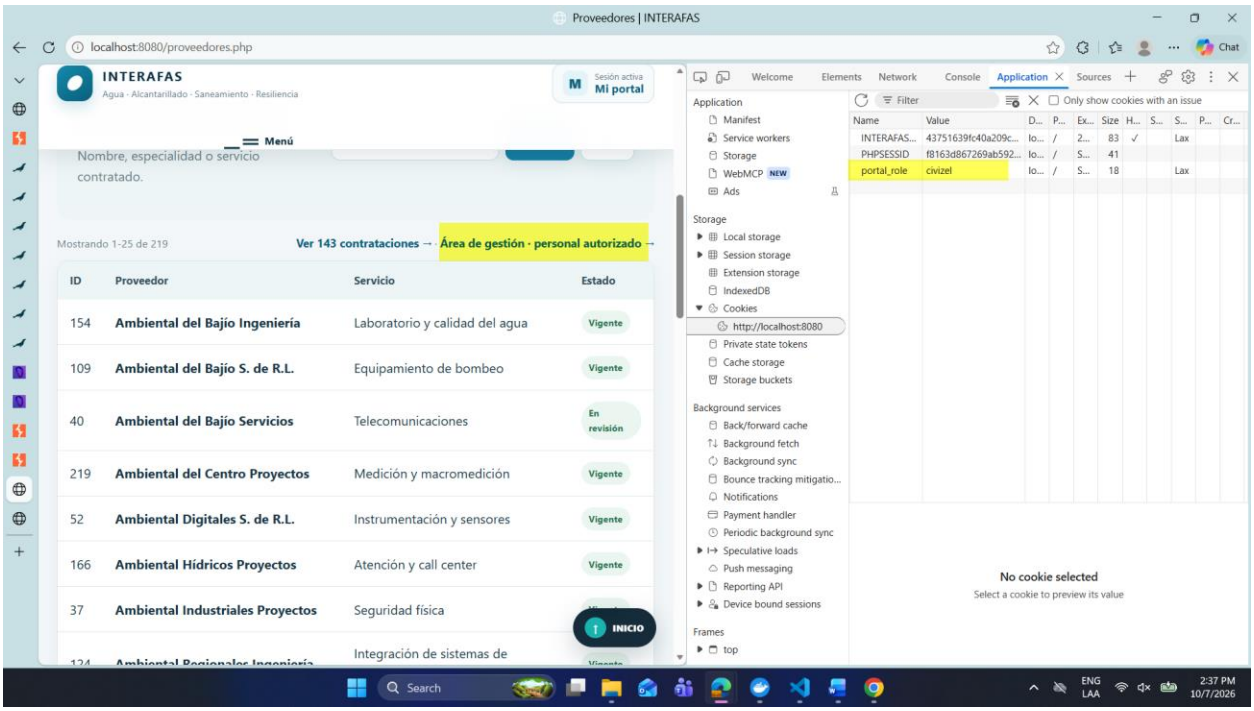
1. Se inició sesión con una cuenta estándar con rol ciudadano (portal_role=citizen).
2. Se intentó acceder a la ruta administrativa protegida /gestion-proveedores.php, obteniendo un código de respuesta HTTP 403 y el encabezado revelador X-Required-Role: procurement_admin.
3. Se emplearon las herramientas de desarrollo (*Application -> Cookies*) o Burp Suite para modificar el valor de la cookie portal_role de citizen a procurement_admin.
4. Se recargó la página, comprobando que el servidor confió ciegamente en el valor manipulado y concedió acceso autorizado al panel de gestión y sus funciones de modificación.

Evidencia técnica:

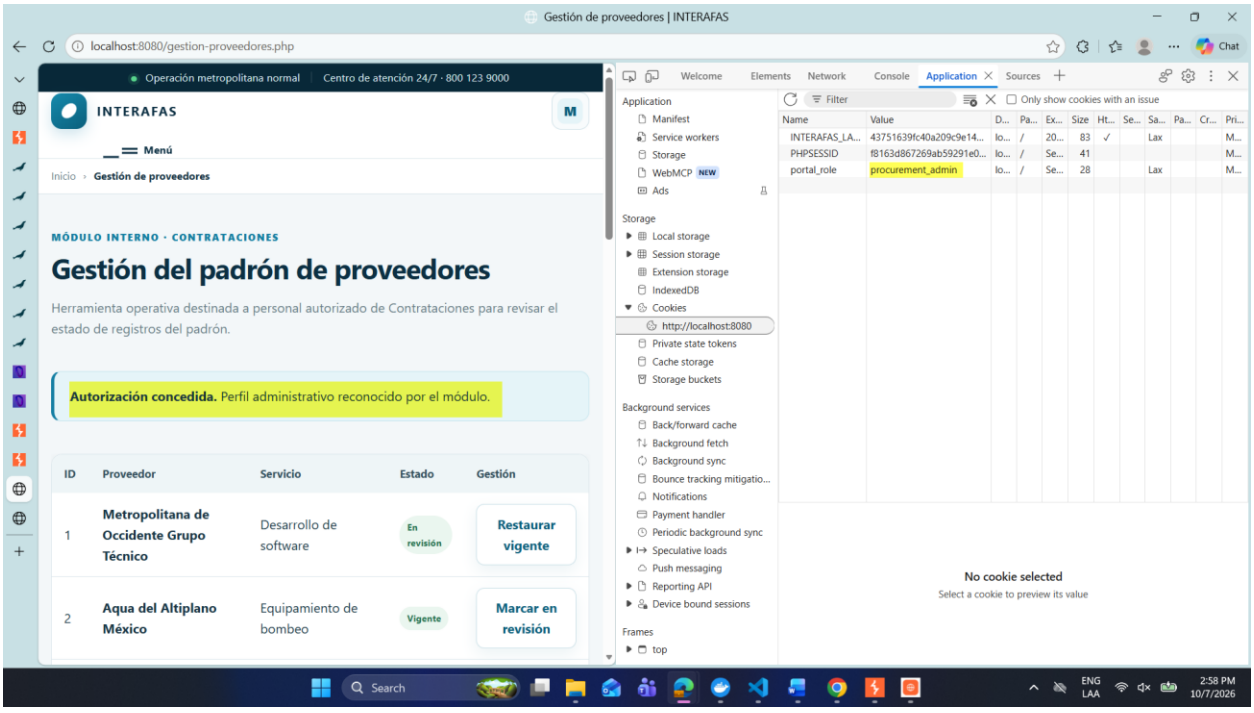
Pagina con acceso autorizado: /proveedores.php



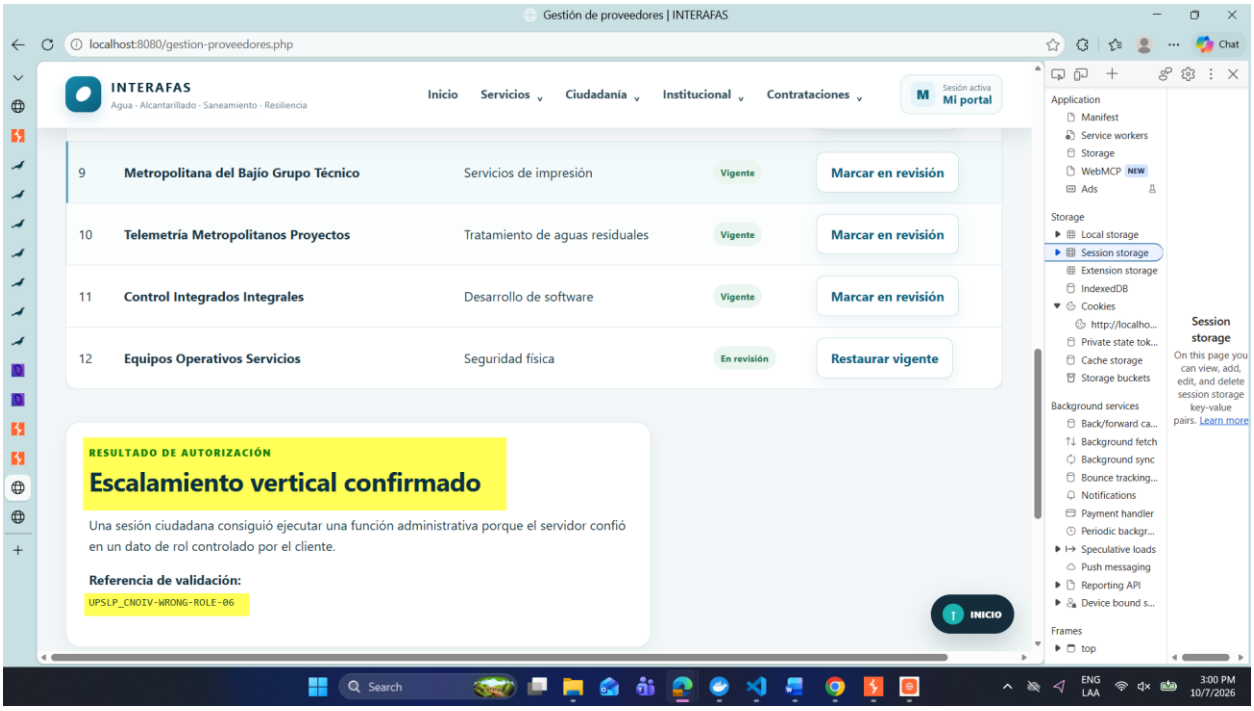
Intercepcion de la petición: GET /gestión-proveedores.php



Cookie manipulada: portal_role=procurement_admin



Resultado en interfaz: "Autorización concedida. Perfil administrativo reconocido por el módulo."



Referencia de validación: UPSLP_CNOIV-WRONG-ROLE-06

Impacto y riesgo:

Nivel de impacto: Crítico / Alto

Confidencialidad: Alta (acceso a padrones de contratación reservados).

Integridad: Alta (permite alterar o restaurar registros de proveedores y contratos de forma no autorizada).

Disponibilidad: Baja.

Escalamiento vertical de privilegios, permitiendo a usuarios ciudadanos ejecutar funciones restringidas de personal autorizado, como restaurar registros de proveedores o modificar contrataciones.

Mitigaciones:

Almacenar los roles y permisos de usuario exclusivamente en el lado del servidor asociándolos al identificador de sesión activo, nunca en cookies o almacenamiento local expuesto a manipulación del cliente.

Reto 07: Inyección SQL Ciega Basada en Inferencia (Blind Boolean)

Descripción técnica y causa raíz:

El parámetro ref del script /validar-referencia.php procesa entradas de texto de forma dinámica concatenándolas directamente dentro de consultas SQL sin sanitización ni

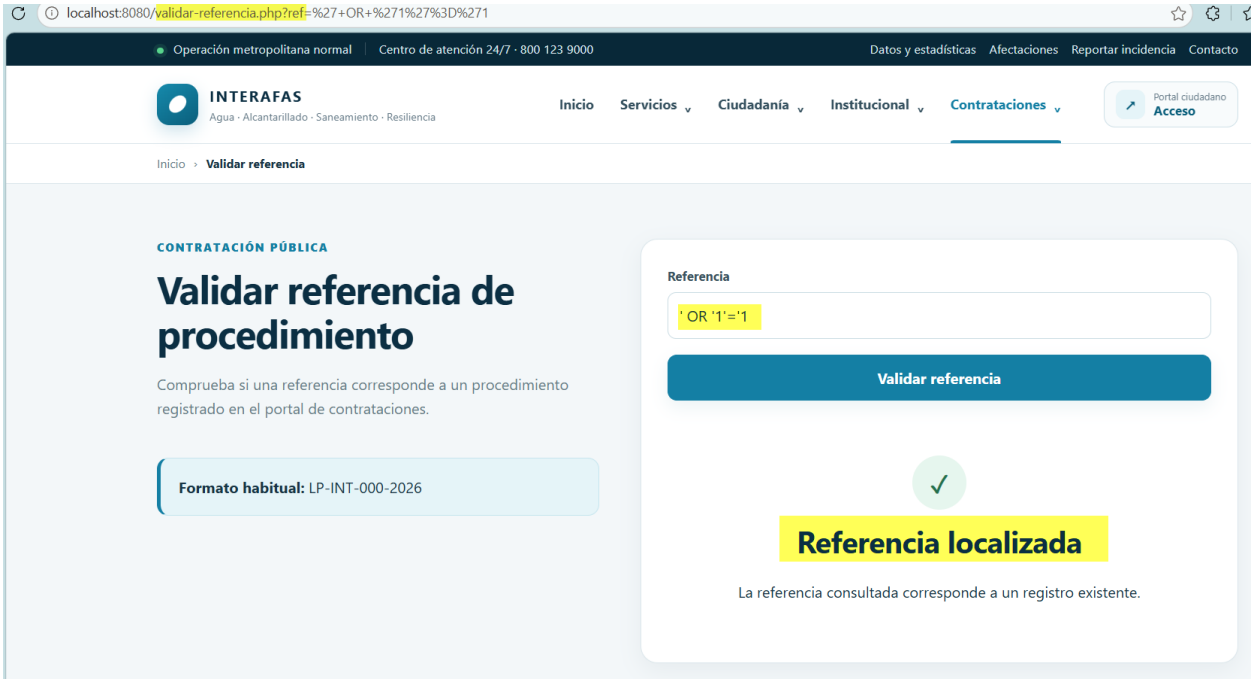
uso de sentencias preparadas. La causa raíz es la vulnerabilidad a Inyección SQL de tipo booleana.

Comprobación de los hallazgos:

1. Se localizó el punto de entrada en el parámetro ref del script /validar-referencia.php?ref=.
2. Se enviaron pruebas de inferencia lógica booleana (' OR '1'='1 vs ' OR '1'='2), observando respuestas diferenciadas ("Referencia localizada" frente a error).
3. Se confirmó la estabilidad del canal lógico y se automatizó la extracción de esquemas, tablas (portal_validation_meta) y columnas (verification_token) utilizando la herramienta sqlmap con la técnica booleana ciega (--technique=B).

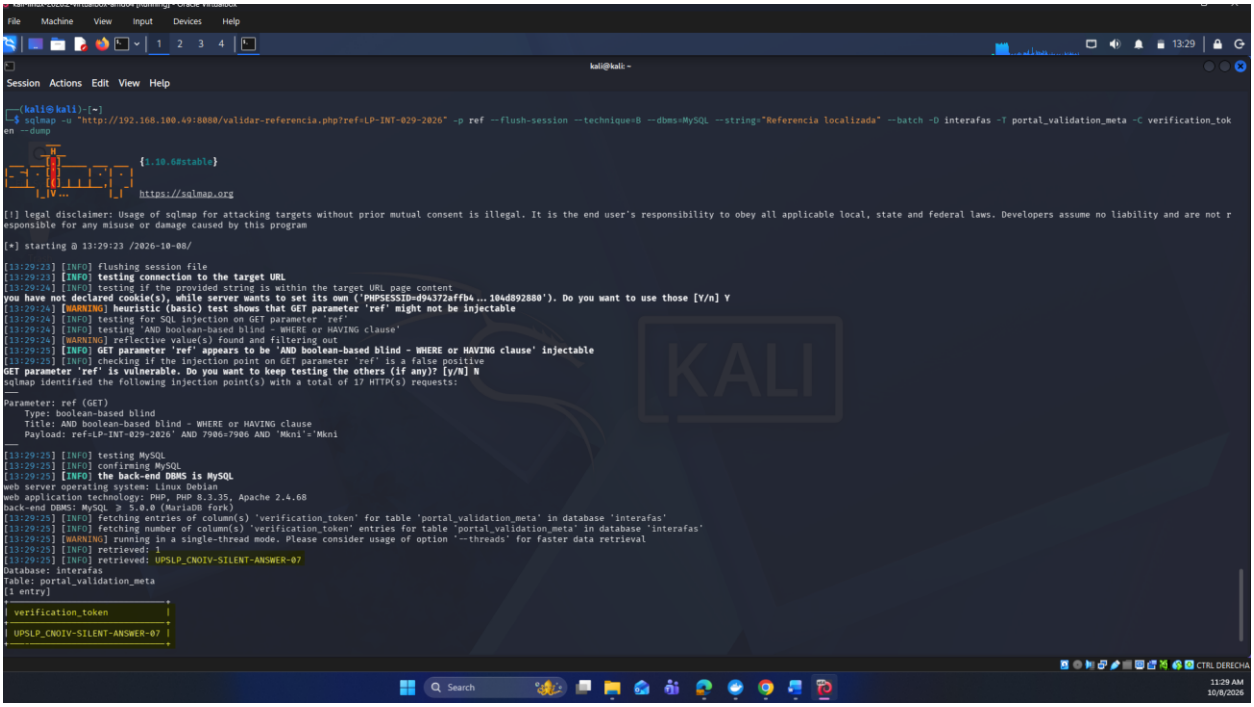
Evidencia técnica:

Condiciones booleanas:



Comando final ejecutado:

sqlmap -u "http://192.168.100.49:8080/validar-referencia.php?ref=LP-INT-029-2026" -p ref --flush-session --technique=B --dbms=MySQL --string="Referencia localizada" --batch -D interafas -T portal_validation_meta -C verification_token --dump



Registro recuperado de la tabla portal_validation_meta: UPSLP_CNOIV-SILENT-ANSWER-07

Impacto y riesgo:

Nivel de impacto: Crítico

Confidencialidad: Crítica (extracción total de tablas, credenciales y registros de la base de datos sin restricciones).

Integridad: Alta.

Disponibilidad: Media.

Acceso no autorizado a la totalidad de las bases de datos del sistema, extracción de credenciales, información ciudadana y alteración o destrucción de registros sensibles.

Mitigaciones:

Utilizar consultas parametrizadas (Prepared Statements con PDO o MySQLi) en todas las operaciones de base de datos que reciban parámetros de usuario.

Reto 08: Inyección de contenido persistente (stored xss)

Descripción técnica y causa raíz:

El formulario de creación de reportes (reportes.php) acepta entradas de texto que se almacenan en la base de datos sin codificación ni validación estricta de caracteres HTML o etiquetas de script. Al consultarse posteriormente en la vista de seguimiento, el

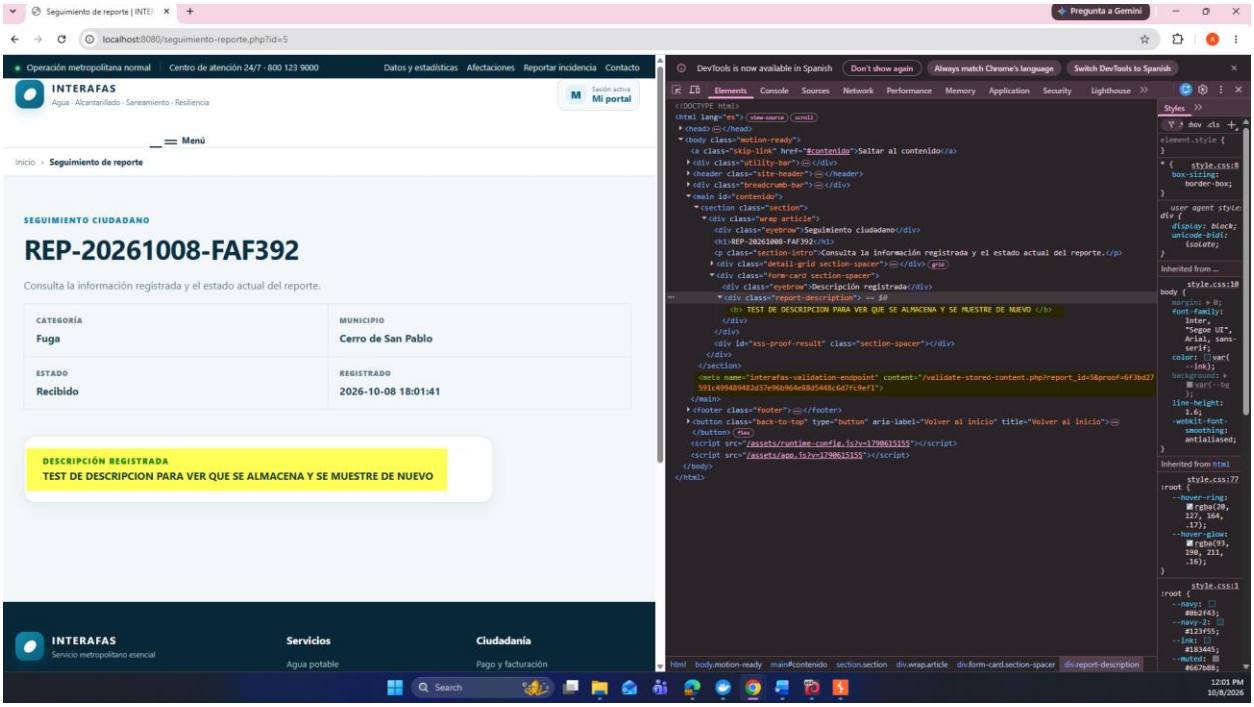
contenido se renderiza directamente en el contexto HTML del navegador. La causa raíz es la falta de escape de salida (Output Encoding).

Comprobación de los hallazgos:

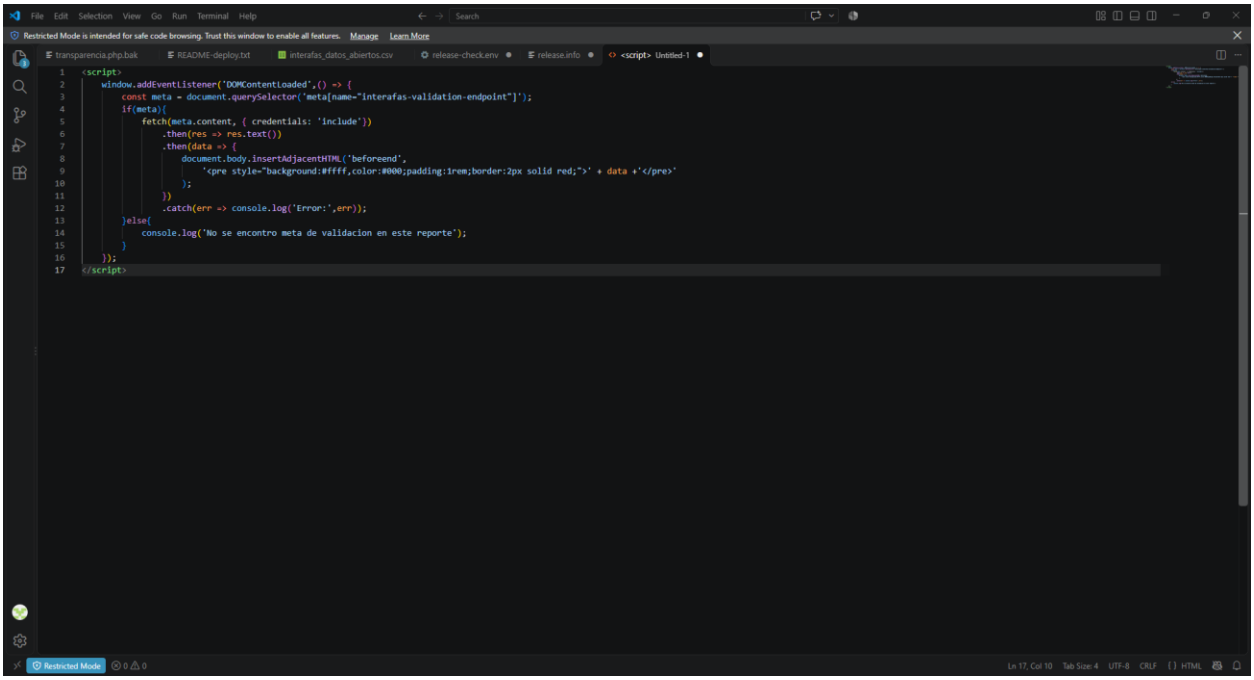
1. Se accedió al formulario de registro de reportes ciudadanos en /reportes.php.
2. Se introdujo un payload malicioso conteniendo etiquetas de script y marcado HTML (<script>alert(1)</script>) en el campo de descripción.
3. Se guardó el reporte y se visitó la ruta de seguimiento /seguimiento-reporte.php?id=.
4. Se comprobó que el servidor almacenó y renderizó el contenido sin codificación, ejecutando dinámicamente el script en el navegador y extrayendo los metadatos de validación.

Evidencia técnica:

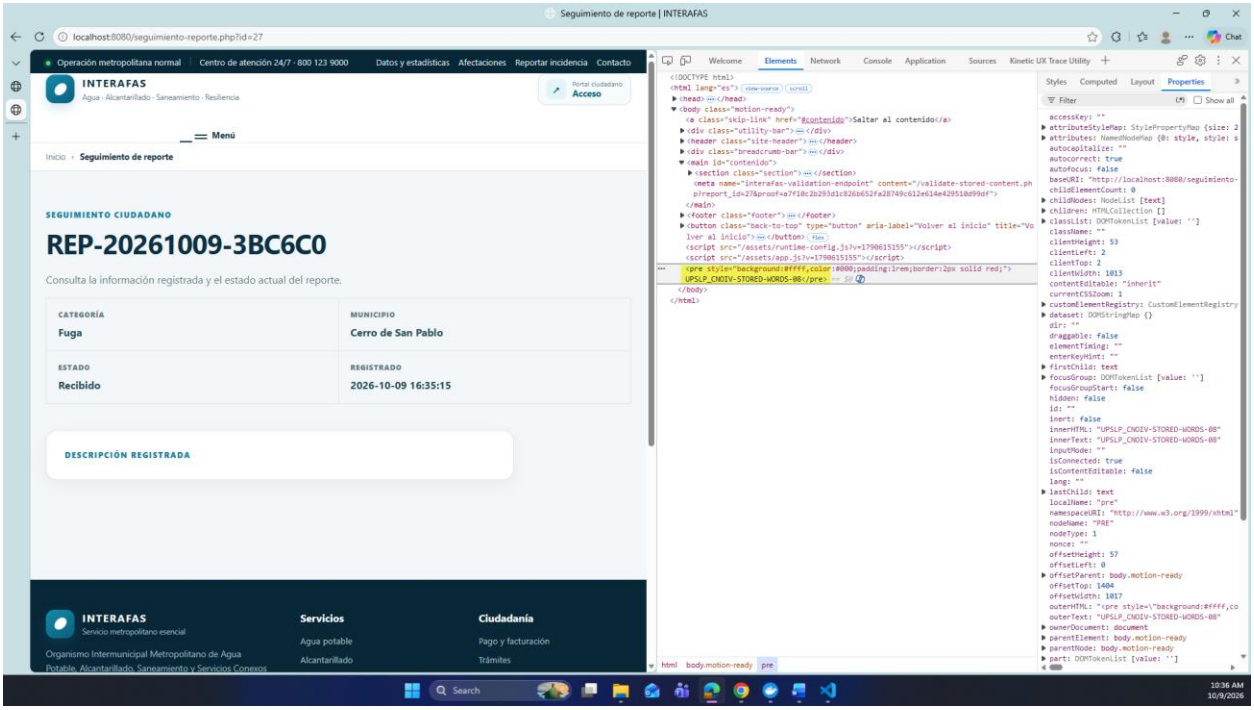
Payload inyectado y ejecutado en el DOM con etiqueta <meta> apuntando a /validate-stored-content.php.



Script:



Bandera recuperada en el elemento <pre> renderizado: UPSLP_CNOIV-STORED-WORDS-08



Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad: Alta (robo de cookies de sesión y tokens de autenticación de otros usuarios o administradores).

Integridad: Alta (modificación del DOM y ejecución de acciones en nombre de la víctima).

Disponibilidad: Media.

Ejecución arbitraria de código JavaScript en el navegador de otros usuarios o administradores que visualicen el reporte, permitiendo el robo de cookies de sesión, suplantación de identidad o redirecciones maliciosas.

Mitigaciones:

Implementar el escape de caracteres especiales HTML en todas las entradas de usuario antes de almacenarlas o renderizarlas en pantalla (funciones como htmlspecialchars() en PHP).

Reto 09: Acceso a Rutas Fuera del Directorio Autorizado (Path Traversal)

Descripción técnica y causa raíz:

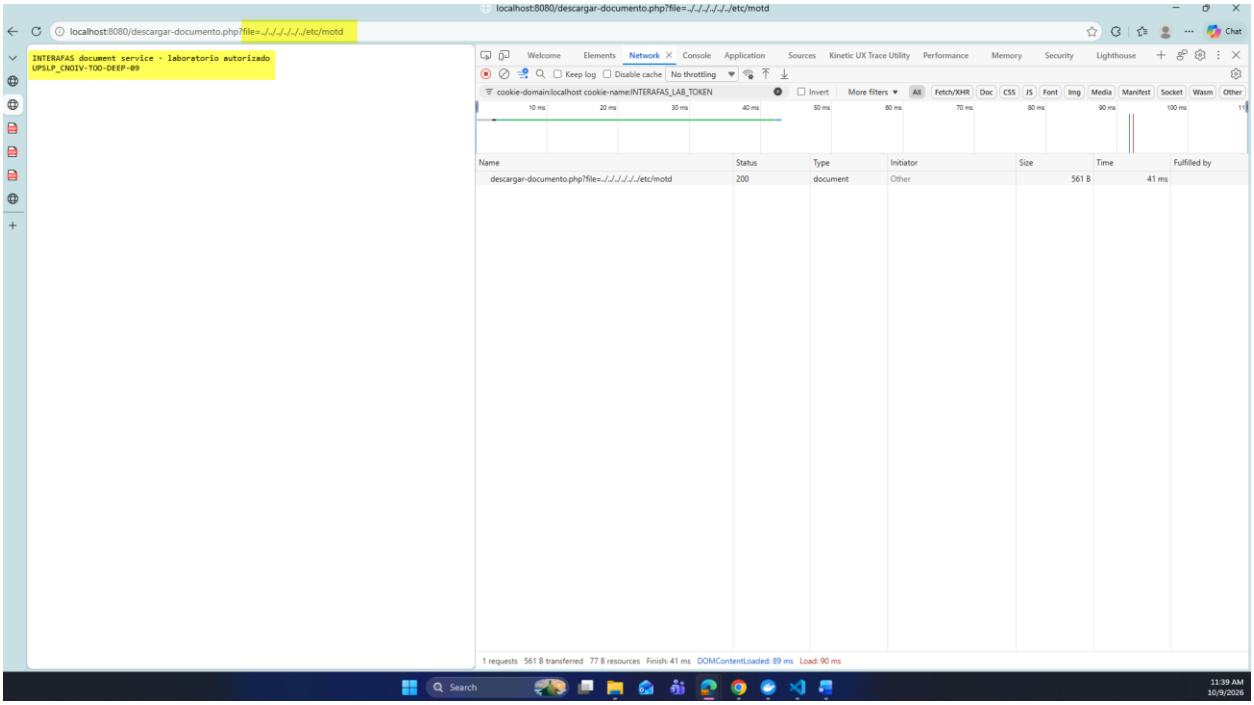
La función de descarga de documentos utiliza un parámetro file= para localizar y entregar archivos del servidor (descargar-documento.php). El script concatena la ruta base del directorio con la entrada del usuario sin validar ni normalizar adecuadamente la presencia de caracteres de navegación de directorios (../). La causa raíz es la falta de validación de rutas y el uso de entradas de usuario directas en funciones de sistema de archivos.

Comprobación de los hallazgos:

1. Se localizó el script de descarga de documentos en /descargar-documento.php?file=.
2. Se inyectaron secuencias repetidas de escape de directorios relativas (../../../../../../etc/motd) en el parámetro file.
3. Se comprobó que el backend concatenó de manera directa la entrada del usuario sin normalización, permitiendo salir del document root y entregar archivos críticos del sistema operativo.

Evidencia técnica:

Petición HTTP: http://localhost:8080/descargar-documento.php?file=../../../../../../etc/motd



Respuesta del servidor (HTTP 200 OK) mostrando el contenido del mensaje del sistema con la bandera: UPSLP_CNOIV-TOO-DEEP-09

Impacto y riesgo:

Nivel de impacto: Alto

***Confidencialidad**:* Alta (lectura arbitraria de archivos del sistema, configuraciones y código fuente).

Integridad/Disponibilidad: Baja.

Lectura de archivos arbitrarios del servidor (configuraciones del sistema, contraseñas cifradas en /etc/passwd, avisos del sistema, código fuente de la aplicación).

Mitigaciones:

Utilizar funciones de normalización y validación estricta como basename() o realpath() para asegurar que el archivo solicitado resida estrictamente dentro del directorio autorizado permitido.

Reto 10: Reutilización de sesión débil (falta de invalidación post-login)

Descripción técnica y causa raíz:

El sistema web asigna un identificador de sesión (PHPSESSID) antes de que el usuario se autentique. Al completar el proceso de inicio de sesión, la aplicación conserva exactamente el mismo identificador de sesión previo en lugar de generar uno nuevo

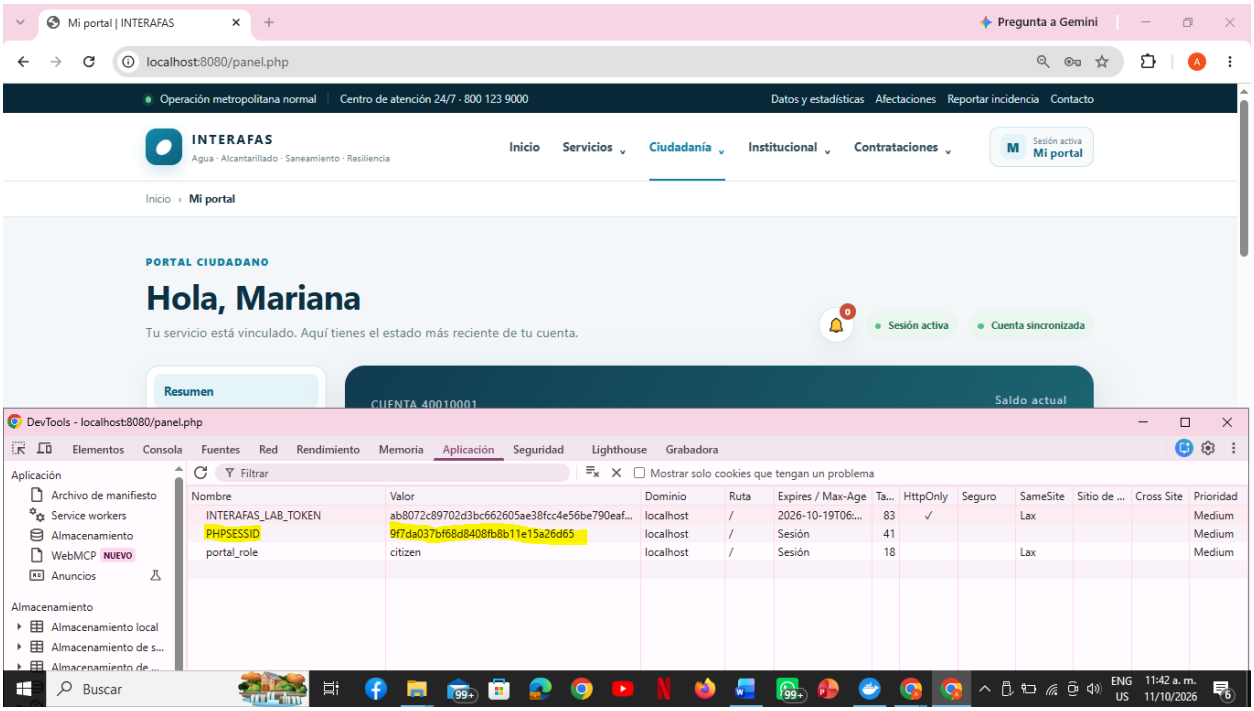
(Session Fixation / Lack of Session Regeneration). La causa raíz es la omisión de la regeneración del ID de sesión tras el cambio de estado de autenticación.

Comprobación de los hallazgos:

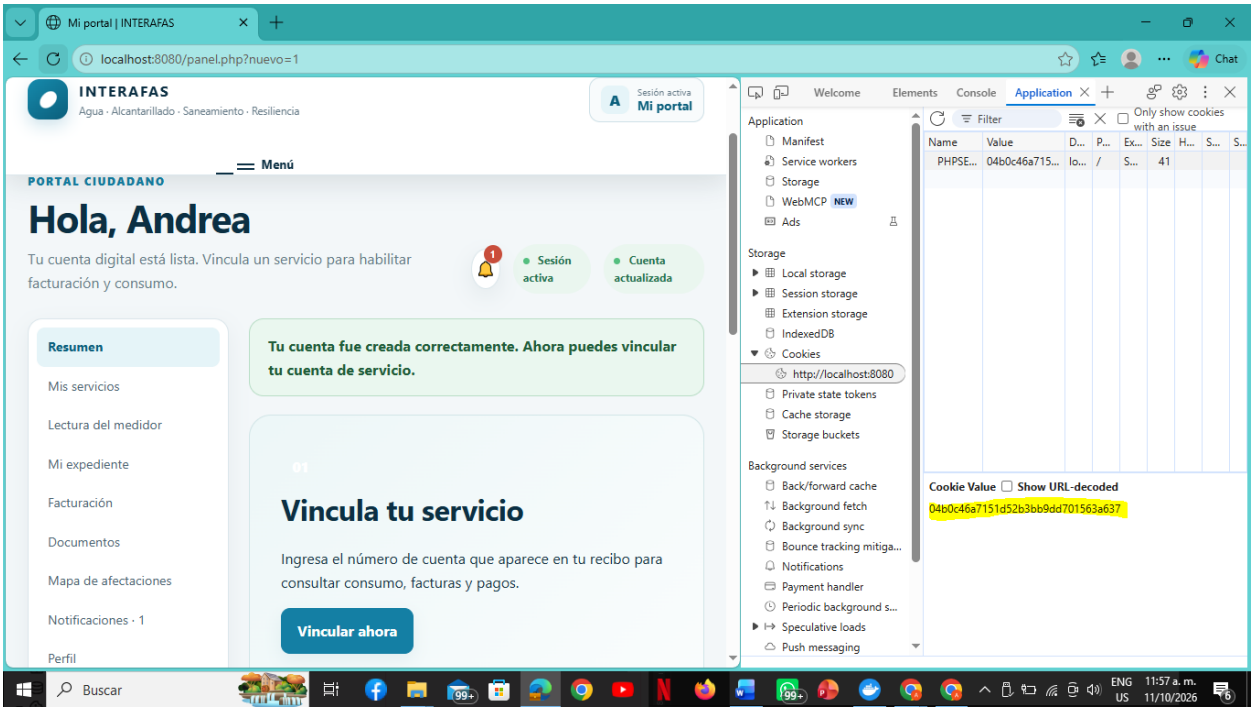
1. Se registró el identificador de sesión anónimo (PHPSESSID) antes de iniciar sesión.
2. Se completó el proceso de autenticación en el portal.
3. Se verificó mediante las herramientas del navegador que el identificador de sesión se mantuvo exactamente idéntico tras el inicio de sesión (*Session Fixation*).
4. Se reutilizó dicho token desde un segundo navegador con un perfil o *User-Agent* diferente, logrando acceder al panel protegido sin proporcionar credenciales.

Evidencia técnica:

Token mantenido con sesion: PHPSESSID = 9f7da037bf68d8408fb8b11e15a26d65

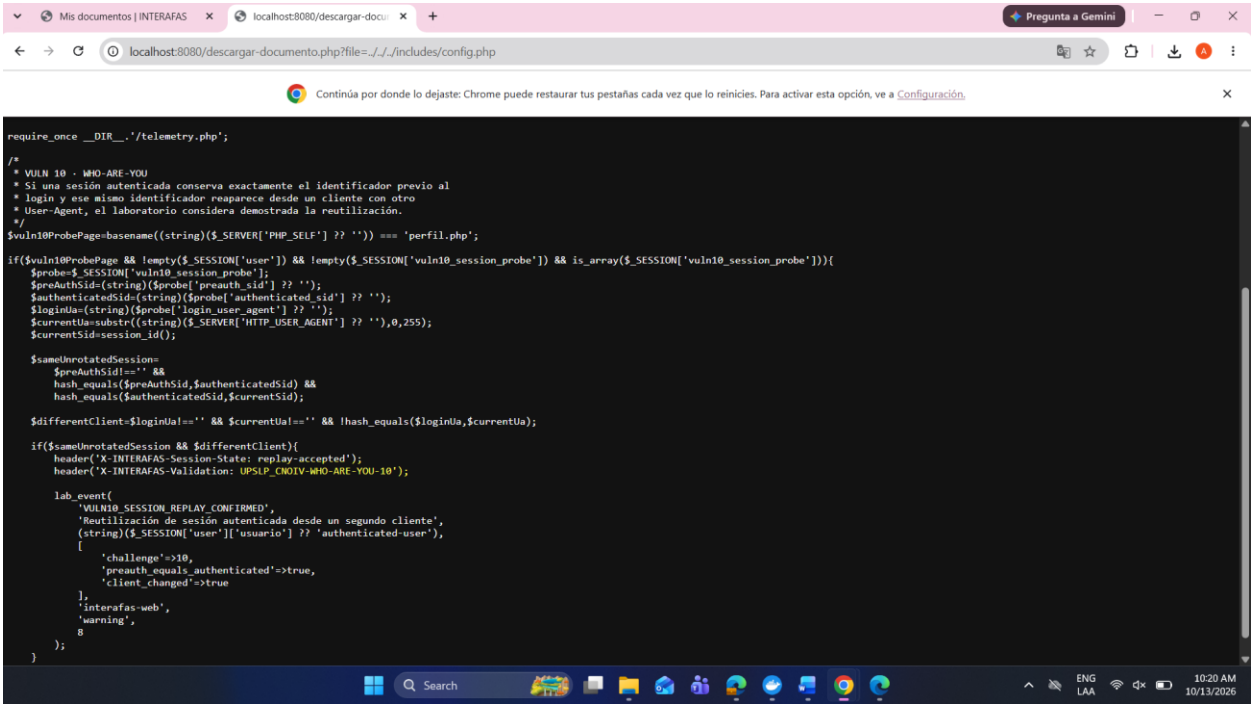


Token desde otro perfil PHPSESSID: 04b0c46a7151d52b3bb9dd701563a637:



Al cambiar la cookie por el de la primera sesión te deja ingresar a su perfil sin necesidad de iniciar sesión.

Código fuente analizado en /includes/config.php detectando la validación de reutilización y generando la cabecera: X-INTERAFAS-Validation: UPSLP_CNOIV-WHO-ARE-YOU-10.



Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad*:* Alta (suplantación de identidad si un atacante fija el token previamente).

Integridad: Alta***.***

Disponibilidad: Media.

Susceptibilidad a ataques de fijación de sesión y reutilización de tokens en caso de que un atacante capture el identificador inicial previo al login de la víctima.

Mitigaciones:

Ejecutar la función de regeneración de sesión (session_regenerate_id(true) en PHP) inmediatamente después de que un usuario se autentique de forma exitosa.

Reto 11: Descubrimiento de endpoint de api no documentado

Descripción técnica y causa raíz:

Durante la navegación por el Portal Ciudadano (panel.php), el frontend realiza peticiones secundarias en segundo plano (AJAX/Fetch) hacia rutas de API. Al inspeccionar el tráfico de red, se identificó un endpoint lógico que responde a peticiones de metadatos de cuenta pero que admite métodos HTTP no documentados públicamente. La causa raíz es la gestión inadecuada del inventario de APIs y la exposición de rutas de servicio sin control de métodos estrictos.

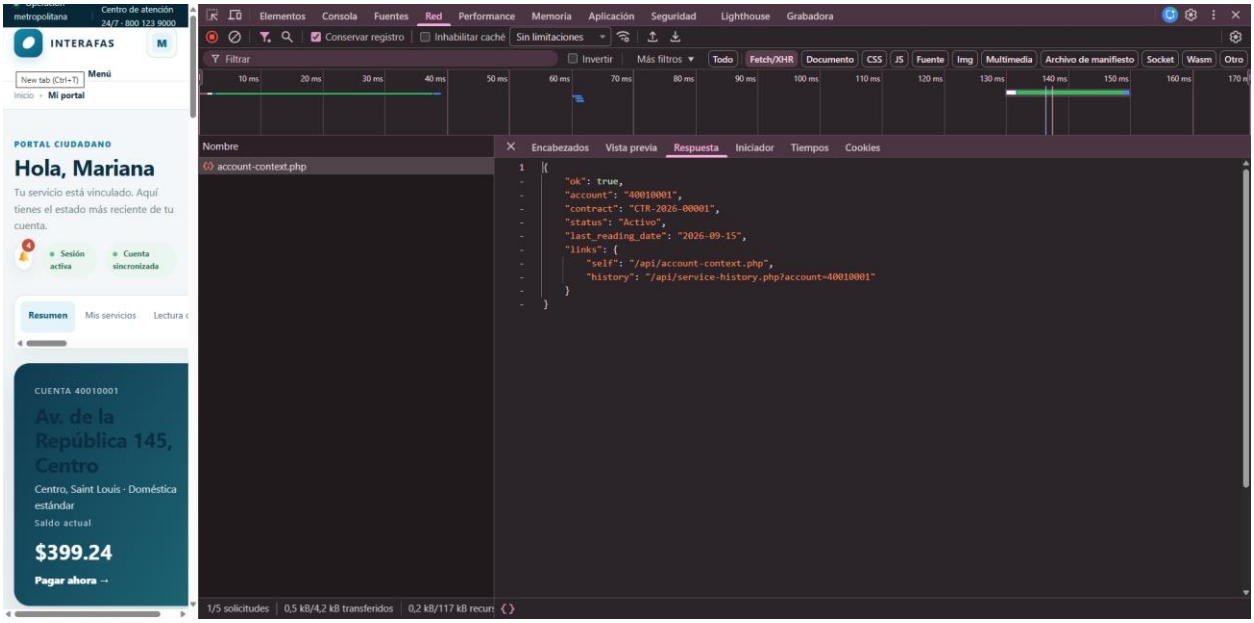
Comprobación de los hallazgos:

1. Se inició la navegación interactiva a través del Portal Ciudadano (/panel.php) manteniendo abiertas las herramientas de desarrollo (*DevTools* -> pestaña *Network* con el filtro XHR/Fetch activo).
2. Se observó que el frontend realizaba peticiones legítimas y documentadas en segundo plano hacia /api/account-context.php.
3. Al inspeccionar minuciosamente el código de respuesta JSON de dicha petición, se identificó un enlace lógico explícito que apuntaba hacia una ruta de servicio secundaria no visible en los menús públicos: /api/service-history.php?account=40010001.
4. Se ejecutó una petición directa de prueba hacia este endpoint, constatando que el servidor respondía con datos financieros e incluía el metadato "documented": false y el encabezado de diagnóstico X-INTERAFAS-Endpoint-Status: undocumented.

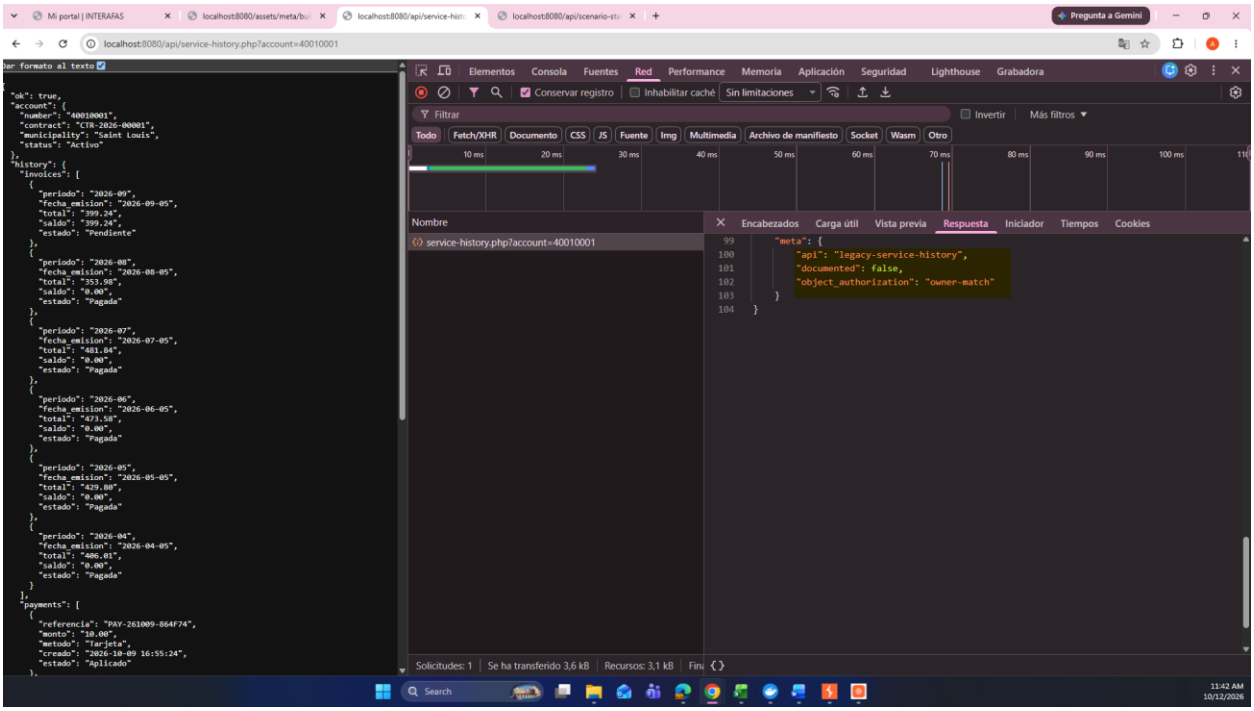
Evidencia técnica:

Pagina vulnerable: /panel.php

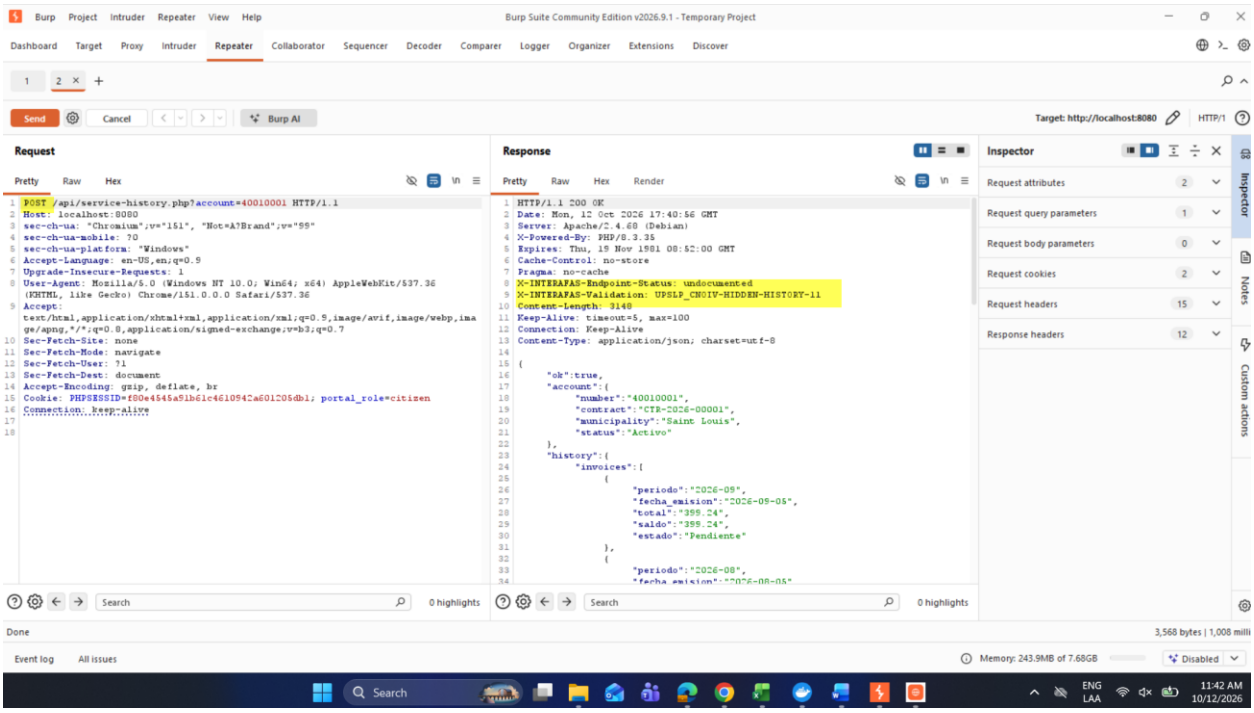
Petición en Segundo plano: account-context.php



Endpoint consultado: /api/service-history.php?account=4001000



Cambio de GET a POST en burpsuite :



Cabecera de respuesta obtenida al cambiar a método POST: X-INTERAFAS-Validation: UPSLP_CNOIV-HIDDEN-HISTORY-11

Impacto y riesgo:

Nivel de impacto: Medio

Confidencialidad: Media, ya que expone históricos de facturación y transacciones de cuentas que no deberían ser accesibles mediante rutas públicas o no oficiales.

Integridsad y Disponibilidad: Baja, al tratarse de un endpoint de solo lectura que no altera directamente el sistema por sí mismo.

Ampliación de la superficie de ataque (Attack Surface) mediante la exposición de endpoints funcionales ocultos que pueden contener lógica de backend vulnerable o desactualizada.

Mitigaciones:

Aplicar una gestión de inventario estricta de APIs y restringir los métodos HTTP permitidos en cada ruta mediante políticas de enrutamiento restrictivas.

Reto 12: Autorización de Objetos Deficiente en API (BCO / IDOR en API)

Descripción técnica y causa raíz:

El endpoint de historial de servicios (/api/service-history.php?account=) recibe un parámetro de cuenta para devolver el estado financiero y de consumo. El backend procesa la solicitud autenticada pero omite comprobar si la cuenta consultada

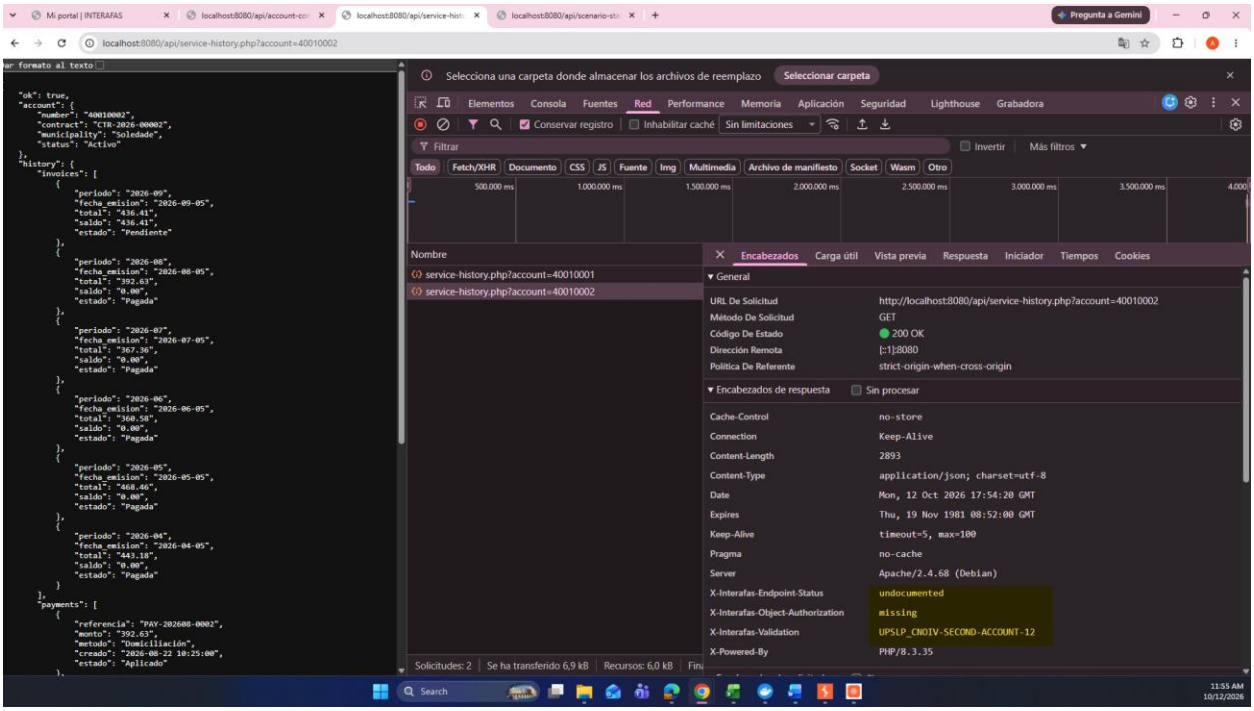
corresponde a la entidad legal del usuario de la sesión actual (Broken Object Level Authorization). La causa raíz es la falta de control de propiedad del recurso a nivel de API.

Comprobación de los hallazgos:

1. Partiendo del endpoint descubierto en el reto anterior (/api/service-history.php), se mantuvo activa la sesión autenticada de un usuario ciudadano legítimo.
2. Se interceptó la petición HTTP o se modificó directamente el parámetro numérico de la cuenta en la URL de account=40010001 a account=40010002.
3. Se analizó la respuesta del servidor, el cual procesó la solicitud omitiendo por completo verificar si el número de cuenta consultado pertenecía legalmente al usuario propietario de la sesión activa.
4. El servidor devolvió un código HTTP 200 OK con el historial financiero completo de la cuenta ajena, incorporando el encabezado X-INTERAFAS-Object-Authorization: missing y la etiqueta JSON "object_authorization": "not-enforced".

Evidencia técnica:

Petición modificada para cuenta ajena.



Cabecera de respuesta del servidor: X-INTERAFAS-Validation: UPSLP_CNOIV-SECOND-ACCOUNT-12

Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad: Alta, permitiendo que cualquier usuario autenticado consulte de forma masiva los estados de cuenta, consumos y deudas de terceros.

Integridad y Disponibilidad: Baja a Media, facilitando la recolección de inteligencia para futuros ataques de fraude o suplantación

Violación grave de la confidencialidad de datos financieros, permitiendo a cualquier usuario consultar historiales de consumo, deudas y pagos de cualquier cliente del organismo.

Mitigaciones:

Validar explícitamente en el backend que el identificador del objeto solicitado esté asociado mediante una relación de propiedad directa a la cuenta del usuario autenticado antes de devolver los datos.

Reto 13: Abuso de lógica de negocio en flujo de pagos

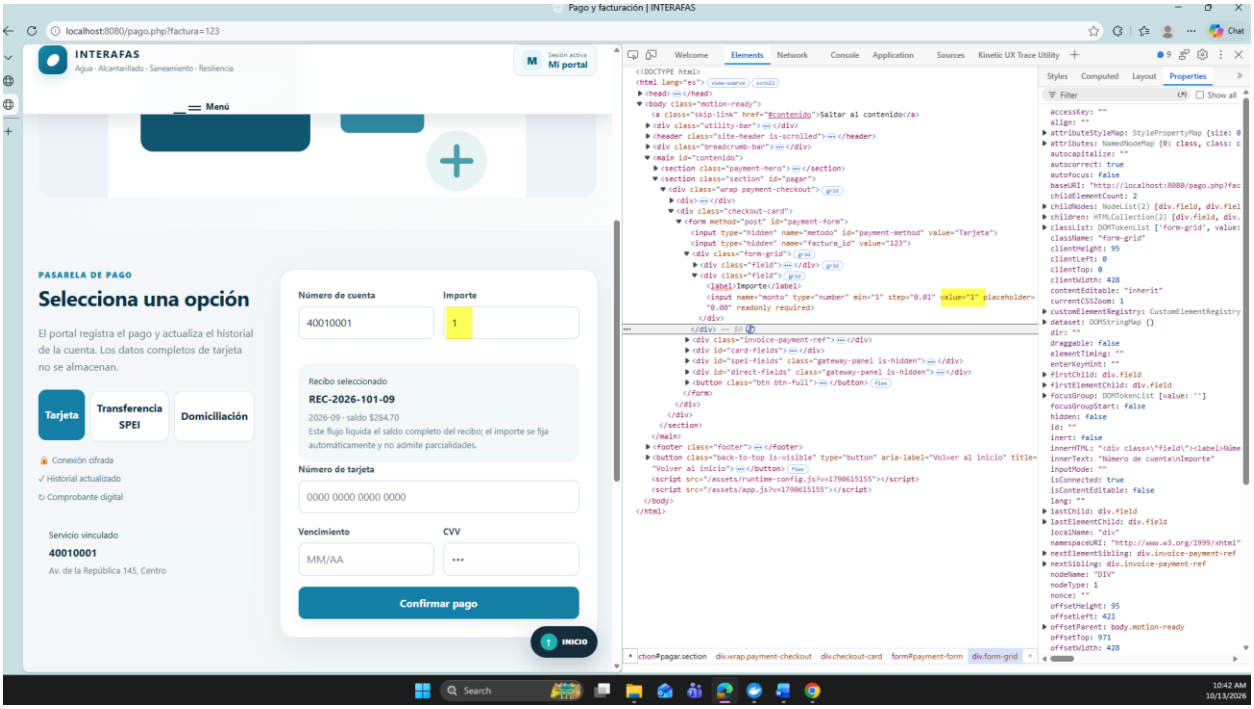
Descripción técnica y causa raíz:

El portal de pagos procesa la liquidación de recibos tomando el valor del monto directamente desde un campo manipulable en el formulario HTML del lado del cliente, sin volver a recalcular ni revalidar el saldo total correspondiente al recibo seleccionado en el servidor de base de datos (amount-not-revalidated). La causa raíz es la confianza en los parámetros financieros enviados por el cliente.

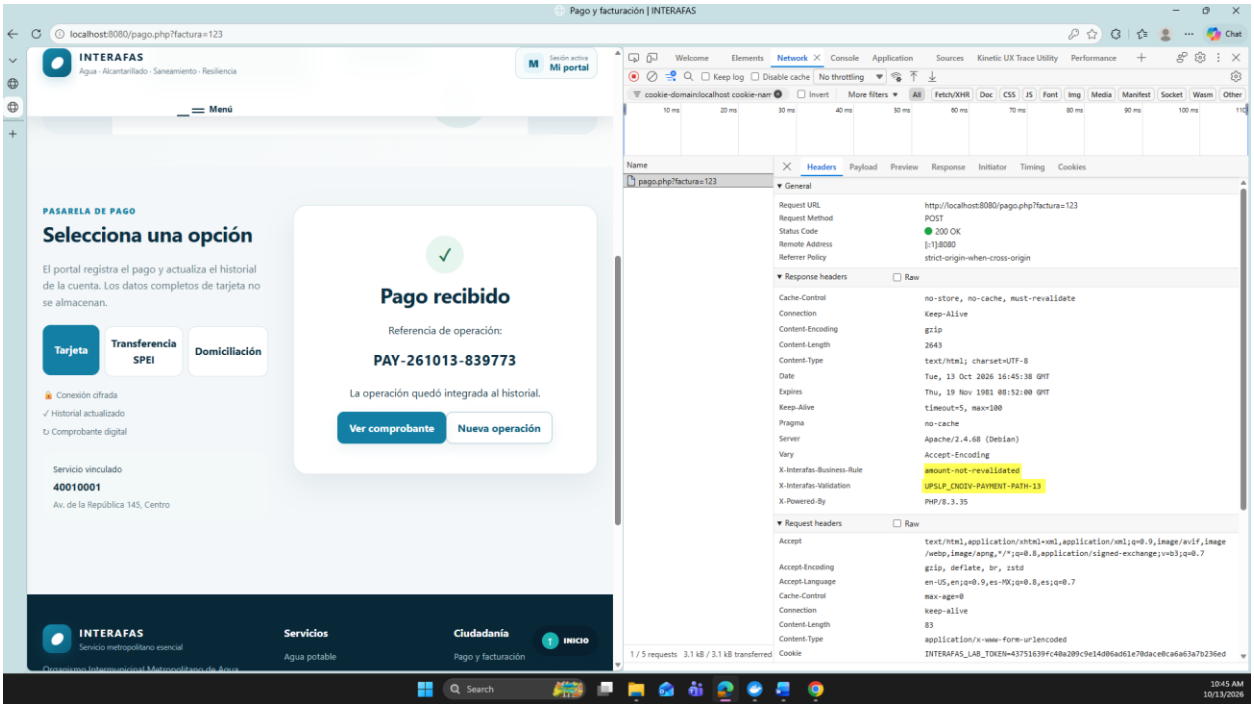
Comprobación de los hallazgos:

Evidencia técnica:

Cabecera de respuesta del servidor confirmando la regla de negocio quebrantada: X-Interafas-Business-Rule: amount-not-revalidated



Cabecera de validación: UPSLP_CNOIV-PAYMENT-PATH-13



Impacto y riesgo:

Pérdida financiera directa, fraude en pasarelas de pago y alteración fraudulenta de estados de cuenta mediante el pago de montos arbitrarios inferiores a la deuda real.

Mitigaciones:

Revalidar siempre los montos, precios y saldos en el servidor consultando directamente la base de datos basándose en el identificador del recibo, ignorando cualquier valor financiero enviado por el formulario del cliente.

Reto 14: Validación deficiente de relaciones entidad contrato-proveedor

Descripción técnica y causa raíz:

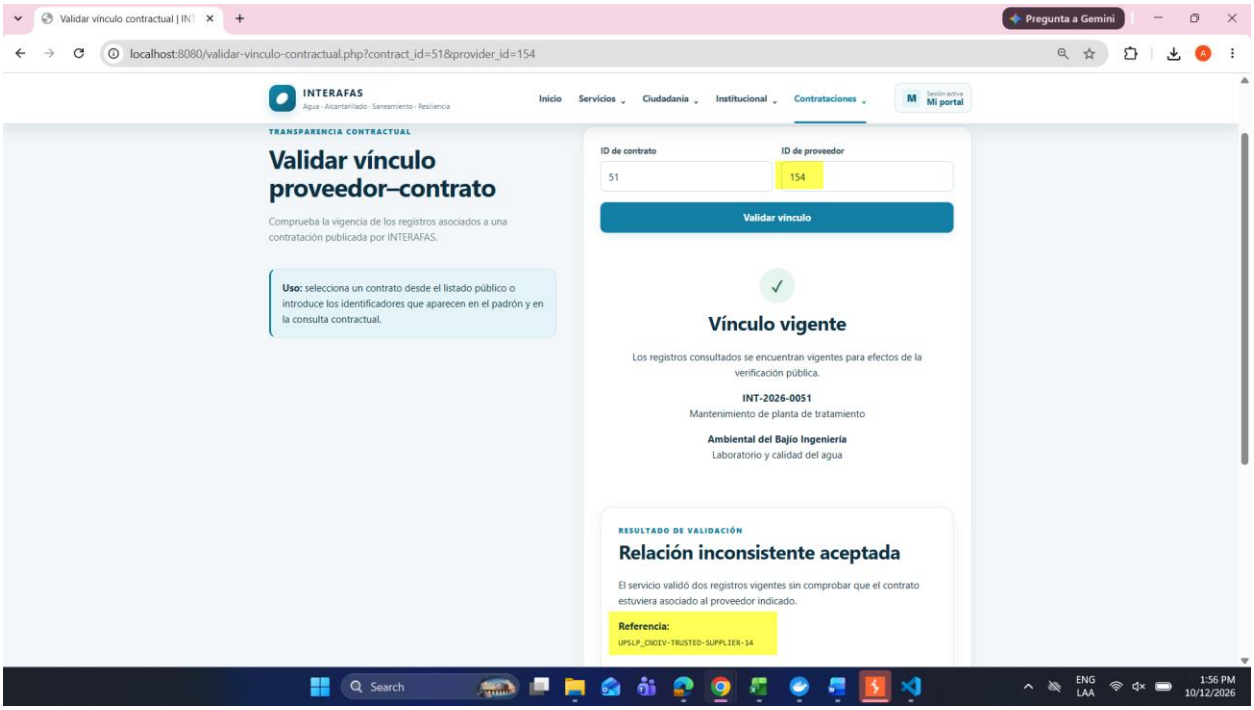
El módulo de transparencia contractual (/validar-vinculo-contractual.php) permite verificar la vigencia de un contrato en relación con un proveedor. Sin embargo, la aplicación valida la existencia y vigencia de cada registro por separado sin comprobar la relación relacional estricta que vincula al proveedor específico con dicho contrato. La causa raíz es la ausencia de validación de integridad relacional en la consulta.

Comprobación de los hallazgos:

Se introdujo un identificador de contrato válido (contract_id=51) combinado con el ID de un proveedor diferente obtenido del padrón público (provider_id=154), observando que el sistema aceptaba el vínculo como válido a pesar de ser inconsistente.

Evidencia técnica:

Resultado de validación en pantalla: "Relación inconsistente aceptada. El servicio validó dos registros vigentes sin comprobar que el contrato estuviera asociado al proveedor indicado."



Referencia: UPSLP_CNOIV-TRUSTED-SUPPLIER-14

Impacto y riesgo:

Falsificación de vínculos contractuales y simulación de adjudicaciones legítimas en portales de transparencia pública.

Mitigaciones:

Incorporar consultas SQL con uniones (JOINS) estrictas que verifiquen la existencia de la llave foránea y la relación directa entre ambas tablas en la base de datos.

Reto 15: Divulgación de arquitectura interna en metadatos de diagnóstico

Descripción técnica y causa raíz:

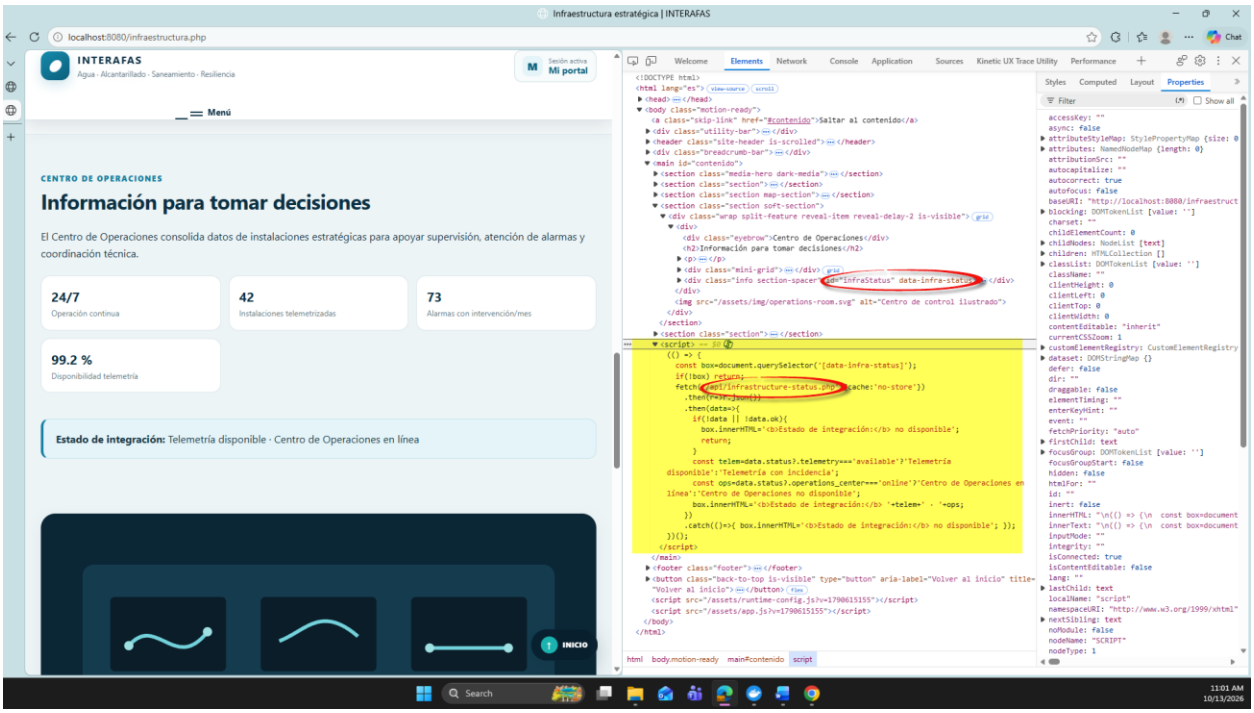
La interfaz de infraestructura estratégica (infraestructura.php) consume un script en segundo plano que consulta el servicio /api/infrastructure-status.php. La respuesta JSON de este servicio incluye metadatos detallados de diagnóstico interno (componentes, fronteras de confianza, segmentos de red CIDR, rutas de aplicación y nombres de servicios internos). La causa raíz es la exposición innecesaria de detalles arquitectónicos a nivel de API pública.

Comprobación de los hallazgos:

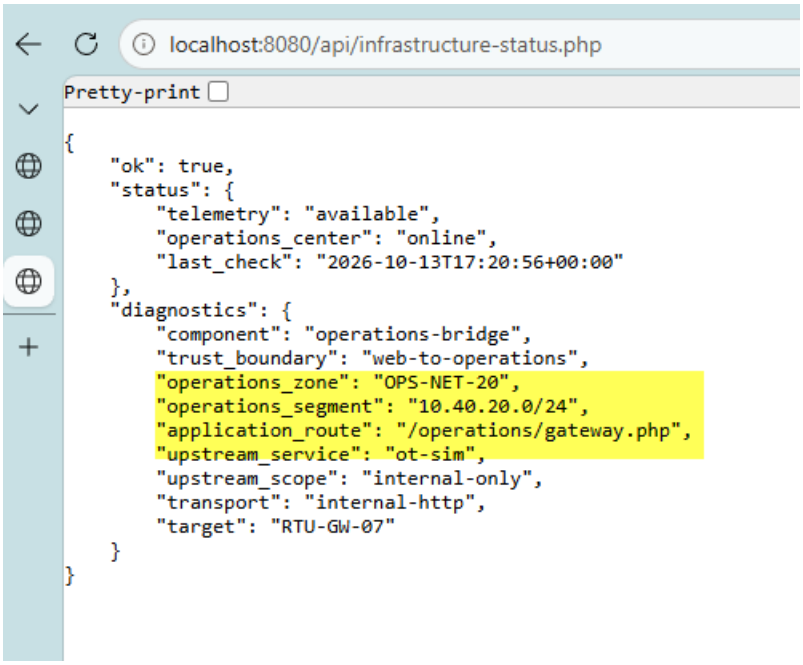
Se visitó la sección de infraestructura y se inspeccionó la respuesta JSON de la petición en la pestaña Red (Network) de las herramientas de desarrollo.

Evidencia técnica:

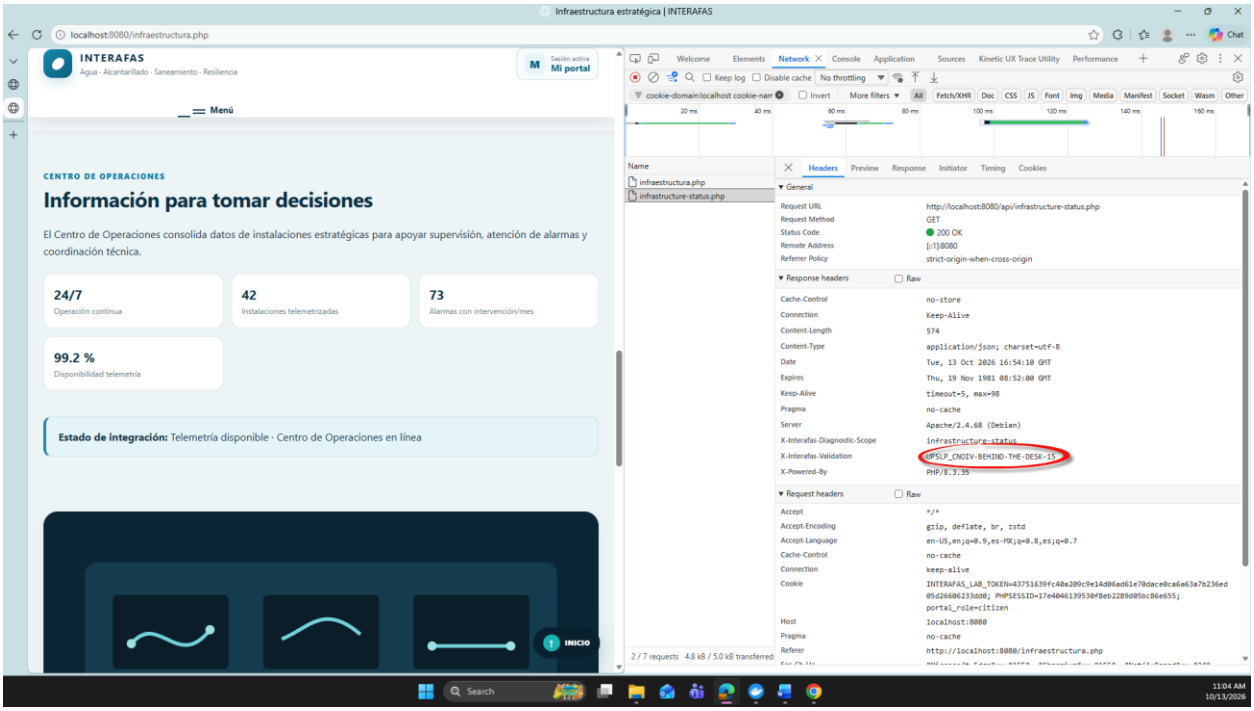
Endpoint consultado: /api/infrastructure-status.php



Datos expuestos: operations_zone: "OPS-NET-20", operations_segment: "10.40.20.0/24", application_route: "/operations/gateway.php"



Cabecera de validación: X-Interafas-Validation: UPSLP_CNOIV-BEHIND-THE-DESK-15



Impacto y riesgo:

Proporciona un mapa claro de la topología de red interna y de los segmentos operacionales (OT) a posibles atacantes, facilitando la planificación de movimientos laterales.

Mitigaciones:

Filtrar la respuesta de las APIs públicas para eliminar información sensible de diagnóstico, direcciones IP internas y esquemas de red antes de enviarlas al cliente.

Reto 16: acceso indebido al gateway mediante suplantación de origen (ip/policy spoofing)

Descripción técnica y causa raíz:

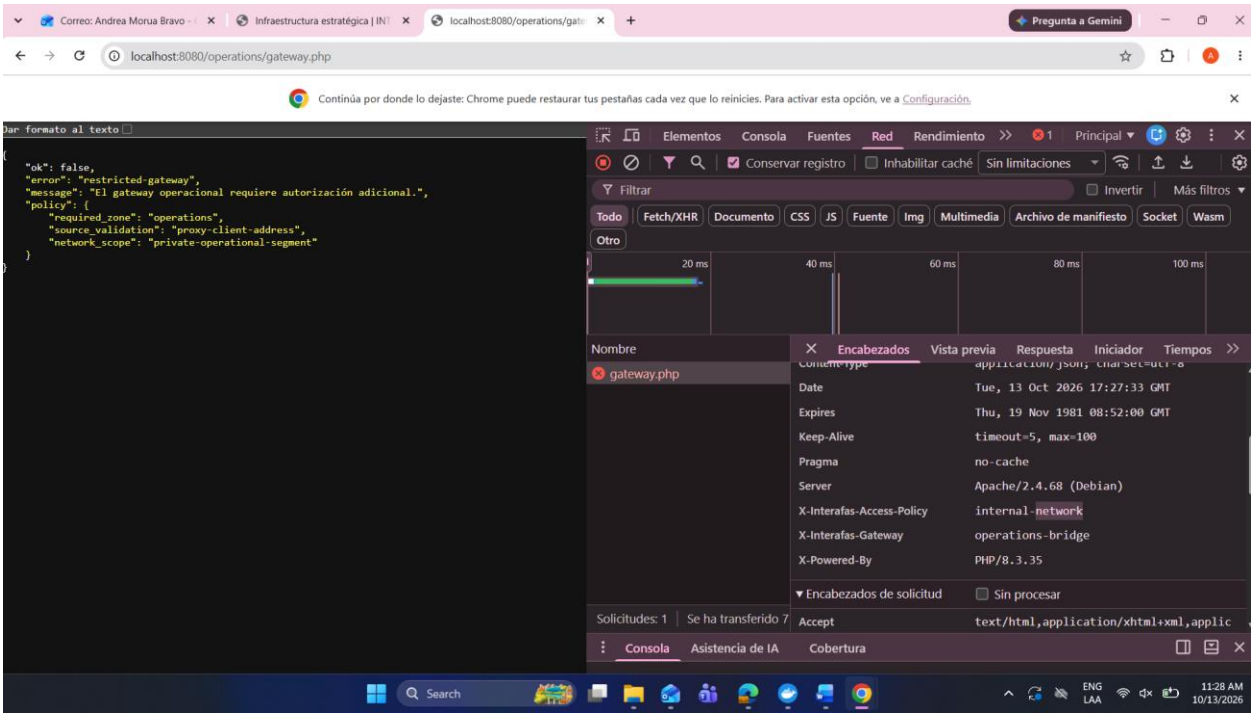
El gateway operacional (/operations/gateway.php) restringe el acceso basándose en políticas de red y zonas operacionales. No obstante, el sistema implementa una verificación débil confiando en cabeceras HTTP controlables por el usuario (como X-Forwarded-For o políticas de acceso customizadas) para determinar si la petición proviene del segmento de red autorizado (10.40.20.0/24). La causa raíz es la confianza en cabeceras de proxy HTTP manipulables.

Comprobación de los hallazgos:

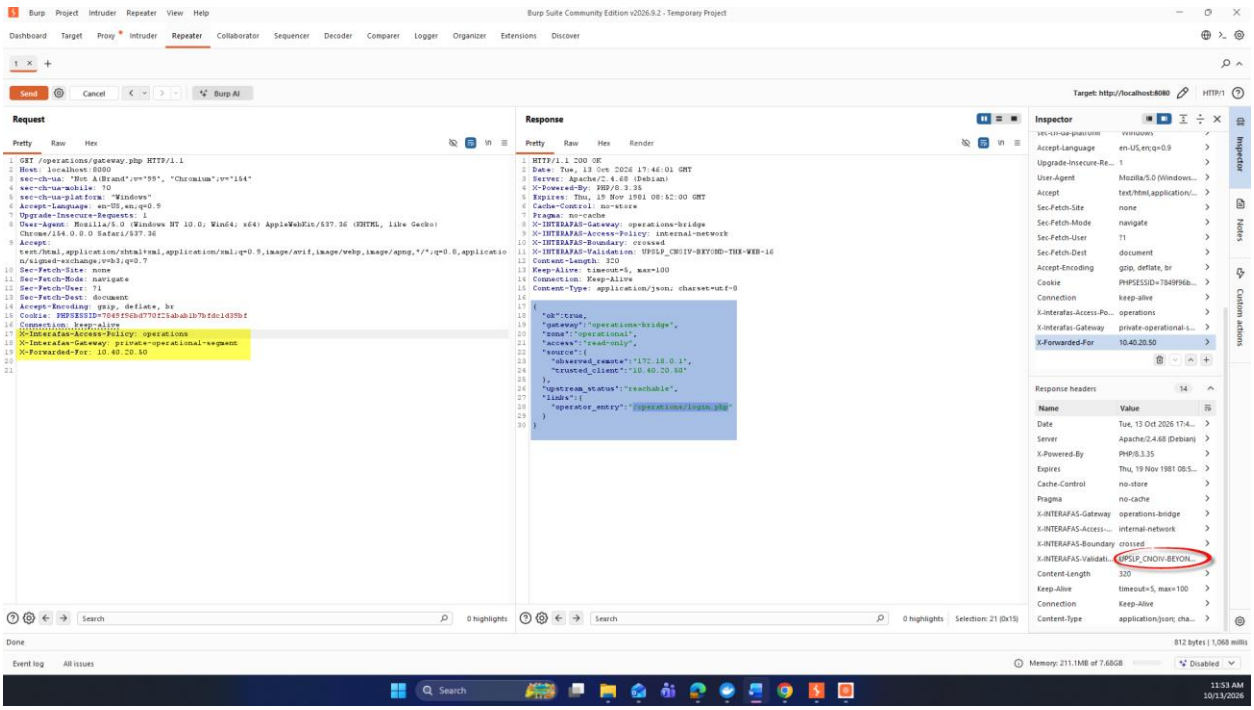
Se interceptó la petición al gateway en Burp Suite, agregando los encabezados correspondientes y simulando la dirección IP perteneciente al segmento operacional expuesto en el reto anterior.

Evidencia técnica:

Encabezados sin autorización operacional:



Encabezados inyectados: X-Interafas-Access-Policy: operations, X-Interafas-Gateway: private-operational-segment, X-Forwarded-For: 10.40.20.50



Cabecera de respuesta con la bandera: X-Interafas-Validation: UPSLP_CNOIV-BEYOND-THE-WEB-16

Impacto y riesgo:

Violación de la segmentación de red perimetral (Bypass de perímetro IT-OT), permitiendo que peticiones externas simulen pertenecer a la red operacional interna de la organización.

Mitigaciones:

Validar la dirección IP real de conexión a nivel de la capa de transporte del servidor web (evitando el uso de cabeceras de reenvío como X-Forwarded-For para decisiones críticas de seguridad a menos que provengan de un proxy inverso confiable y cifrado).

Reto 17: Acceso no autorizado a vistas operacionales hmi y telemetría

Descripción técnica y causa raíz:

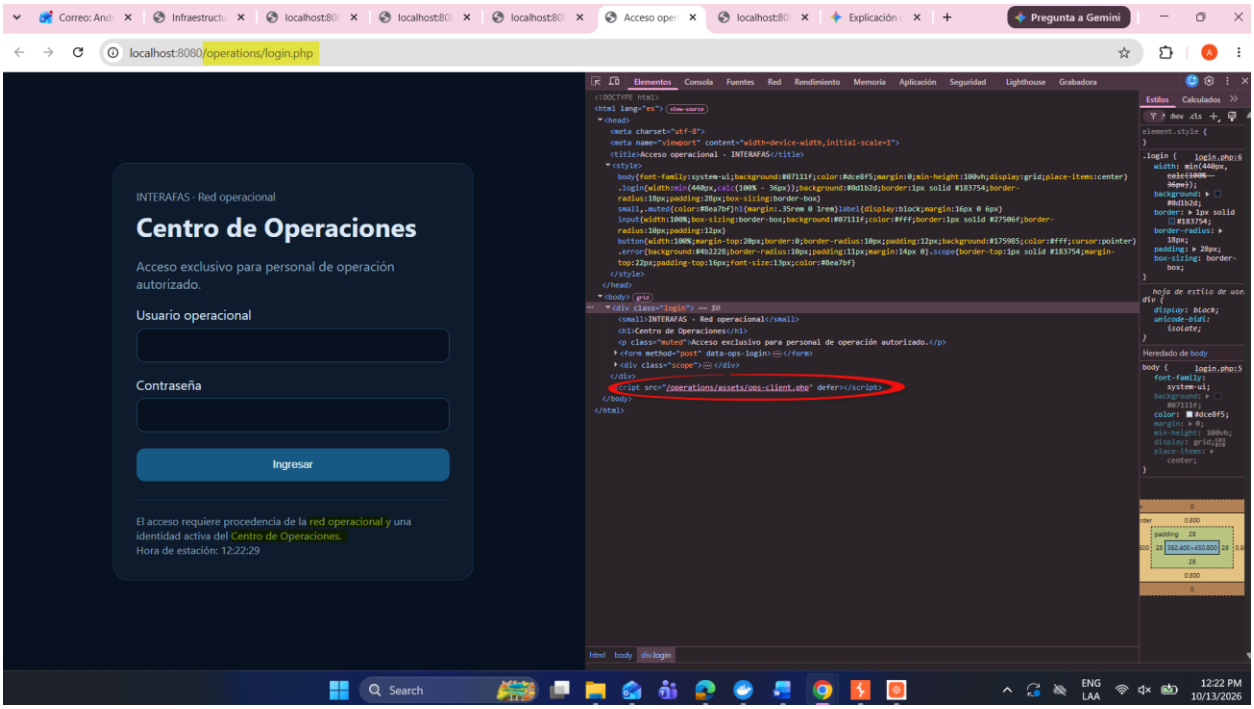
Tras superar la validación del gateway operacional, la ruta /operations/login.php conduce al Centro de Operaciones. Sin embargo, se descubrió un script a /ops-client.php y nos dirigió a el endpoint secundario de telemetría /operations/telemetry.php responde directamente entregando información crítica en formato JSON sin exigir una sesión activa validada de operador HMI. La causa raíz es la ausencia de control de autenticación robusto en el endpoint de datos operacionales.

Comprobación de los hallazgos:

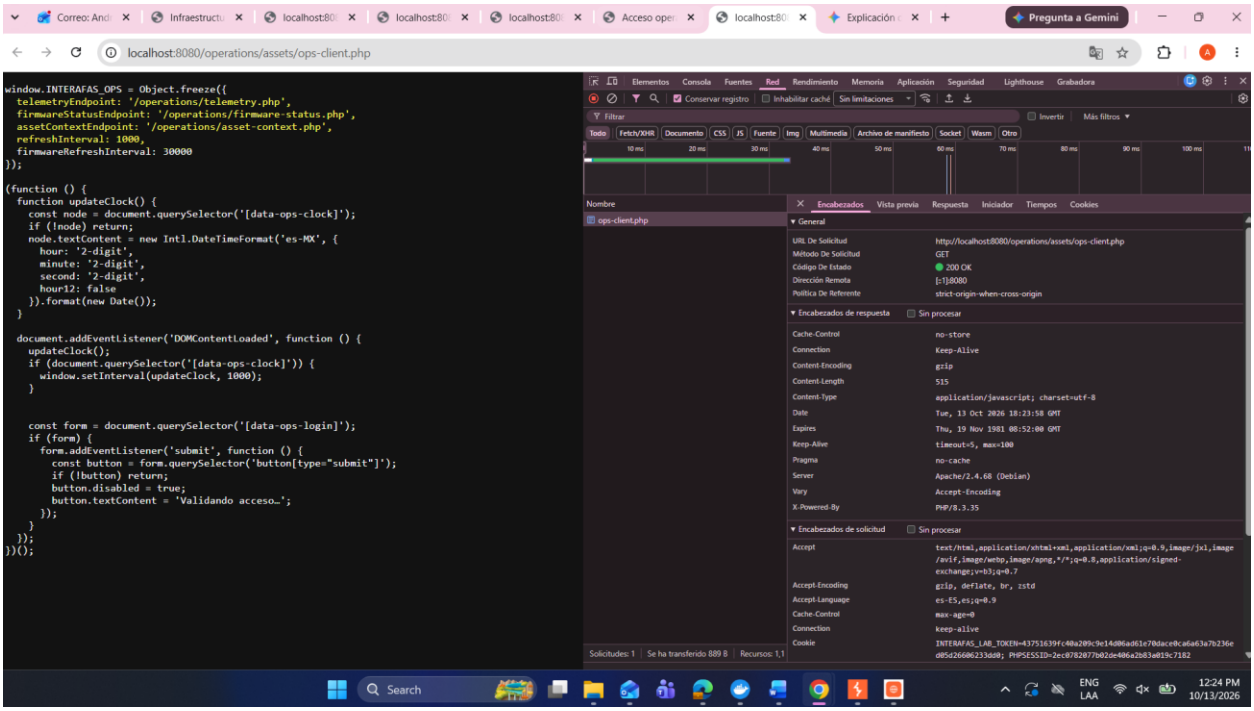
1. Utilizando el acceso al gateway consolidado mediante la suplantación de IP del reto anterior, se procedió a inspeccionar los scripts frontales del Centro de Operaciones, específicamente /operations/assets/ops-client.php.
2. Se identificaron los endpoints secundarios de monitoreo declarados en el cliente, tales como /operations/telemetry.php y /operations/firmware-status.php.
3. Se realizaron peticiones directas y deliberadas a estas rutas sin proporcionar credenciales ni contar con una sesión de operador HMI activa.
4. El servidor respondió con un estado HTTP 200 OK entregando un flujo masivo de datos industriales sensibles en formato JSON, corroborado por los encabezados X-INTERAFAS-Monitoring-Authorization: network-only y X-INTERAFAS-Operational-Session: missing

Evidencia técnica:

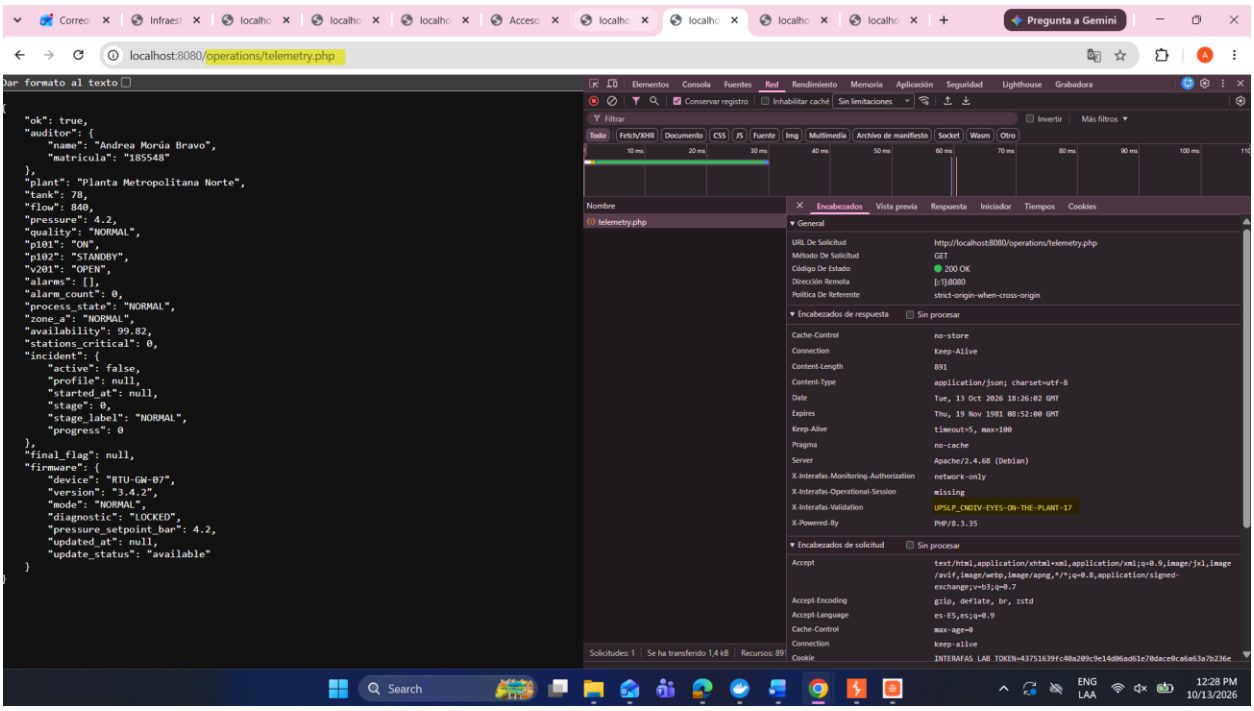
Ruta revelada: /operations/login.php



Ruta del script: /assets/ops-client.php



Endpoint consultado: /operations/telemetry.php



Respuesta JSON incluyendo datos de planta, tanques, flujos y la cabecera: X-Interafas-Validation: UPSLP_CNOIV-EYES-ON-THE-PLANT-17

Impacto y riesgo:

Nivel de impacto: Crítico

Confidencialidad: Crítica, exponiendo el estado en tiempo real de infraestructura nacional o municipal crítica (niveles de tanques, presiones de agua, caudales, apertura de válvulas, alarmas activas y registros de auditoría).

Integridad y Disponibilidad: Media, facilitando la comprensión operativa del entorno físico para futuras disrupciones.

Exposición de estados operacionales en tiempo real de instalaciones de infraestructura crítica (agua potable, presión, tanques y alarmas) a usuarios no autorizados.

Mitigaciones:

Forzar la validación estricta de cookies y roles de sesión de operador en todos los scripts de backend que procesen telemetría industrial.

Reto 18: validación defectuosa de actualización de firmware simulado (fuerza bruta de hash)

Descripción técnica y causa raíz:

El canal de actualización de firmware (/operations/updates/manifest.php) expone un verificador heredado basado en un hash SHA-1

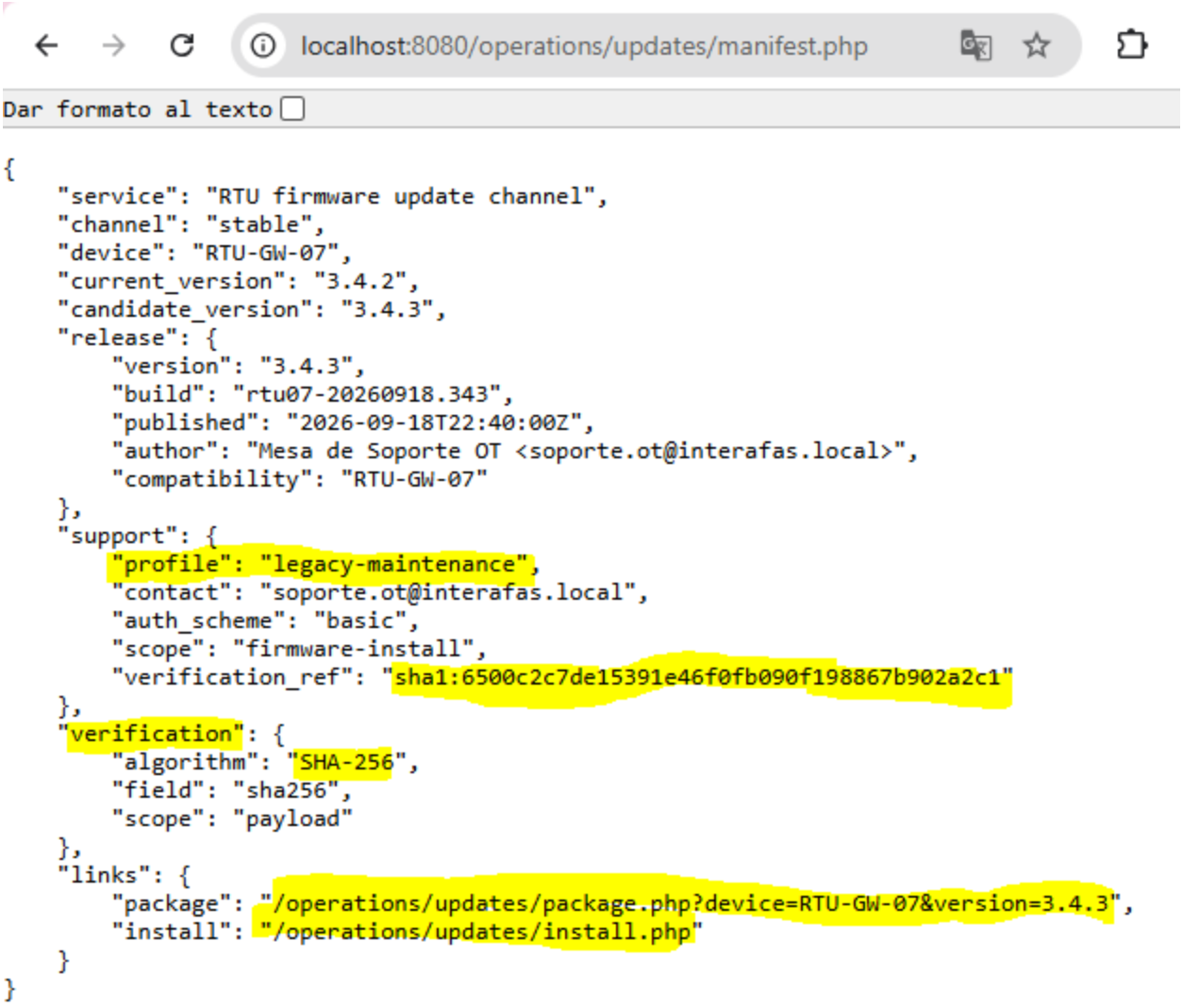
(6500c2c7de15391e46f0fb090f198867b902a2c1) y acepta la instalación de paquetes remotos si el payload coincide con la suma de verificación provista. La causa raíz es el uso de algoritmos criptográficos obsoletos (SHA-1) y la ausencia de una firma digital real emitida por una autoridad emisora confiable.

Comprobación de los hallazgos:

1. Se examinó el canal de actualizaciones en /operations/updates/manifest.php, identificando una referencia de verificación heredada basada en un hash SHA-1 débil (6500c2c7de15391e46f0fb090f198867b902a2c1).
2. Se analizó el hash utilizando la herramienta hashid
3. Se empleó la herramienta de descifrado *Hashcat* en conjunto con un diccionario específico para realizar un ataque de fuerza bruta sobre el hash SHA-1, logrando recuperar en texto claro la credencial de soporte técnico (soporte.ot:Soporte343).
4. Se construyó un paquete de firmware modificado alterando los parámetros operativos de diagnóstico a un estado no seguro ({"mode":"MAINTENANCE","diagnostic":"UNLOCKED"}).
5. Se calculó el nuevo hash SHA-256 del payload modificado y se envió la actualización al instalador mediante una petición HTTP autenticada con las credenciales obtenidas y el spoofing de IP, verificando que el servidor aceptó el paquete únicamente comprobando la suma de verificación sin validar una firma digital legítima del fabricante

Evidencia técnica:

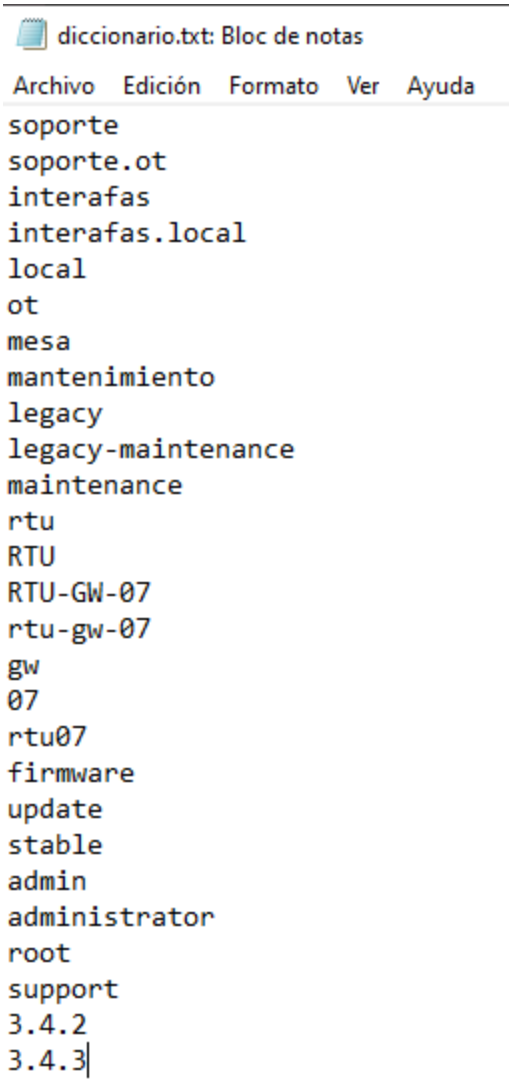
URL: /operations/updates/manifest.php



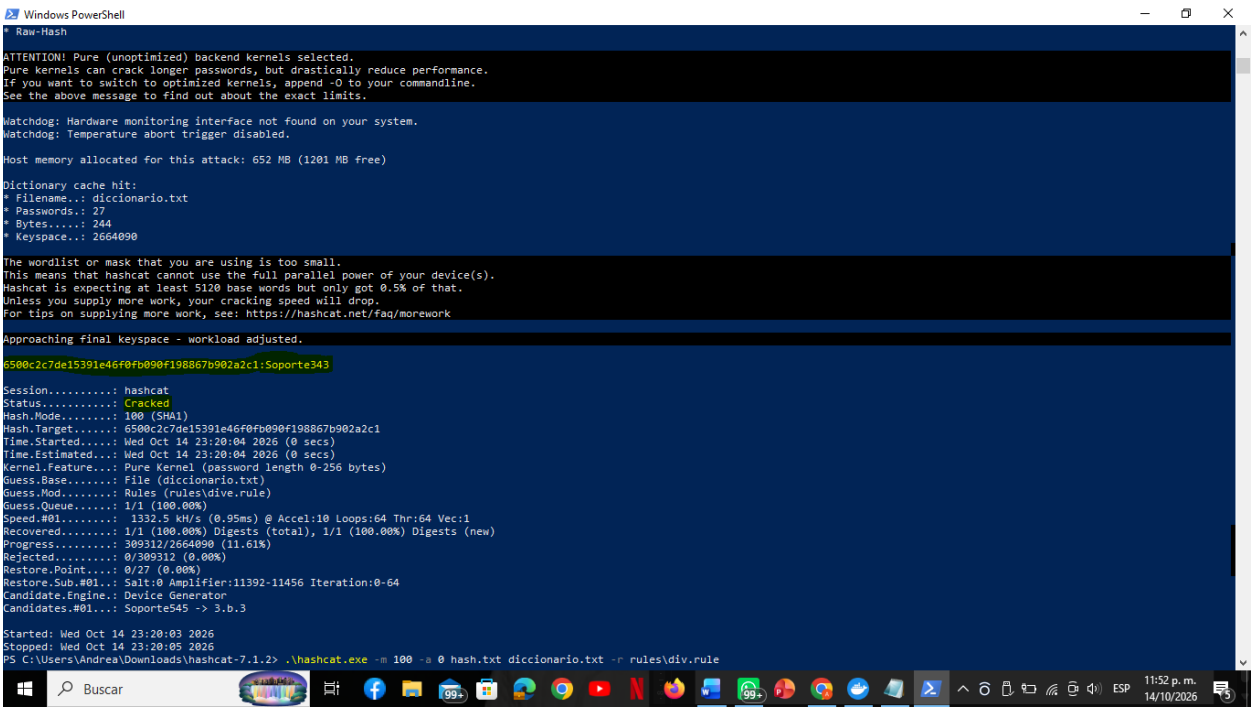
Clasificación del hash:



Diccionario utilizado:



Hash crackeado: 6500c2c7de15391e46f0fb090f198867b902a2c1 → Soporte343



Nuevo hash de carga útil generado:
a0918623aedb0f0e440dc2315a9c6108762c70f6380c2bc0c2bc1a41c3fd7caf

```
PS C:\Users\Andrea\Downloads\hashcat-7.1.2> $nuevo_payload = '{"mode":"NORMAL","diagnostic":"UNLOCKED"}'
PS C:\Users\Andrea\Downloads\hashcat-7.1.2> $bytes = [System.Text.Encoding]::UTF8.GetBytes($nuevo_payload)
PS C:\Users\Andrea\Downloads\hashcat-7.1.2> $hash = [System.Security.Cryptography.SHA256]::Create().ComputeHash($bytes)
PS C:\Users\Andrea\Downloads\hashcat-7.1.2> [System.BitConverter]::ToString($hash).Replace("-","").ToLower()
a0918623aedb0f0e440dc2315a9c6108762c70f6380c2bc0c2bc1a41c3fd7caf
PS C:\Users\Andrea\Downloads\hashcat-7.1.2>
```

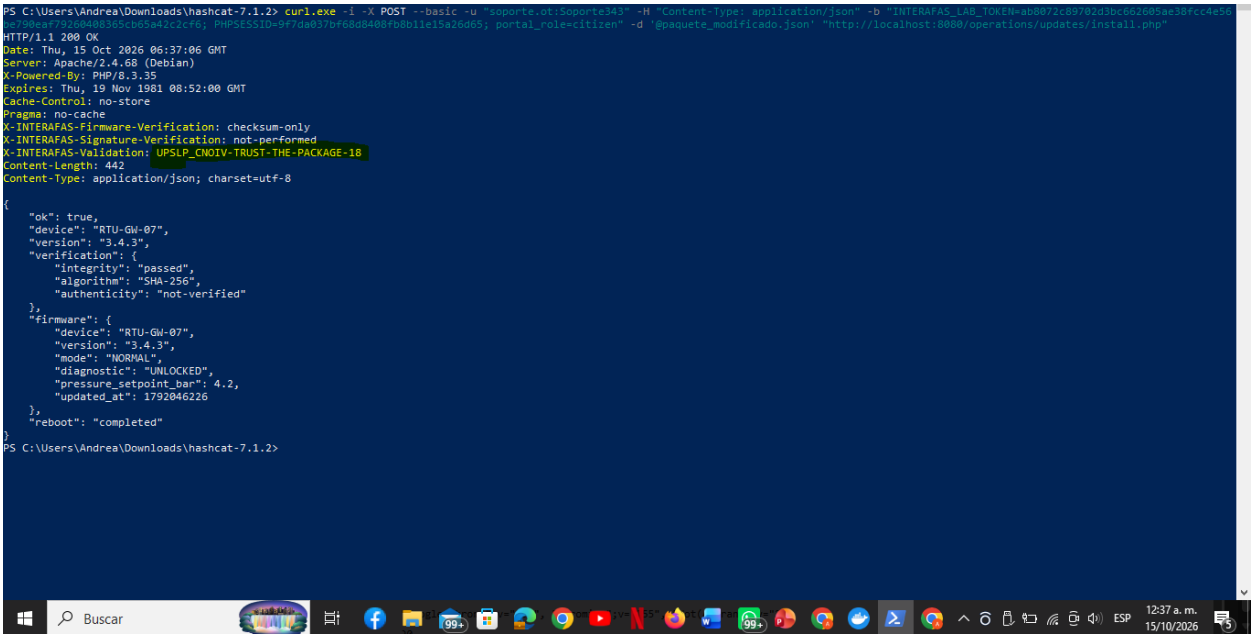
JSON modificado:

paquete_modificado.json: Bloc de notas

Archivo Edición Formato Ver Ayuda

```
{
    "device": "RTU-GW-07",
    "version": "3.4.3",
    "payload": "{\"mode\":\"NORMAL\",\"diagnostic\":\"UNLOCKED\"}",
    "sha256": "a0918623aedb0f0e440dc2315a9c6108762c70f6380c2bc0c2bc1a41c3fd7caf"
}
```

Bandera obtenida: UPSLP_CNOIV-TRUST-THE-PACKAGE-18



Impacto y riesgo:

Nivel de impacto: Crítico

Confidencialidad: Media.

Integridad y Disponibilidad: Críticas, permitiendo inyectar, modificar y ejecutar código de firmware malicioso en dispositivos de control industrial remotos (RTUs/PLCs), lo que puede paralizar o destruir la automatización de la planta.

Permite la inyección y ejecución de paquetes de firmware modificados o maliciosos en los dispositivos de control remoto (RTU/PLC), comprometiendo por completo la integridad del proceso industrial.

Mitigaciones:

Reemplazar SHA-1 por algoritmos criptográficos robustos (SHA-256/SHA-512) e implementar un esquema de infraestructura de clave pública (PKI) con firmas digitales firmadas por el fabricante para validar la autenticidad de las actualizaciones de firmware.

Reto 19: Encadenamiento de hallazgos it-ot (cadena de dependencias hmi)

Descripción técnica y causa raíz:

El rol de mantenimiento (maintenance) dentro del panel de activos HMI (/operations/) posee excesivos privilegios operativos que permiten interactuar con la cadena completa de dependencias físicas y lógicas sin requerir una reautenticación estricta (exceso de

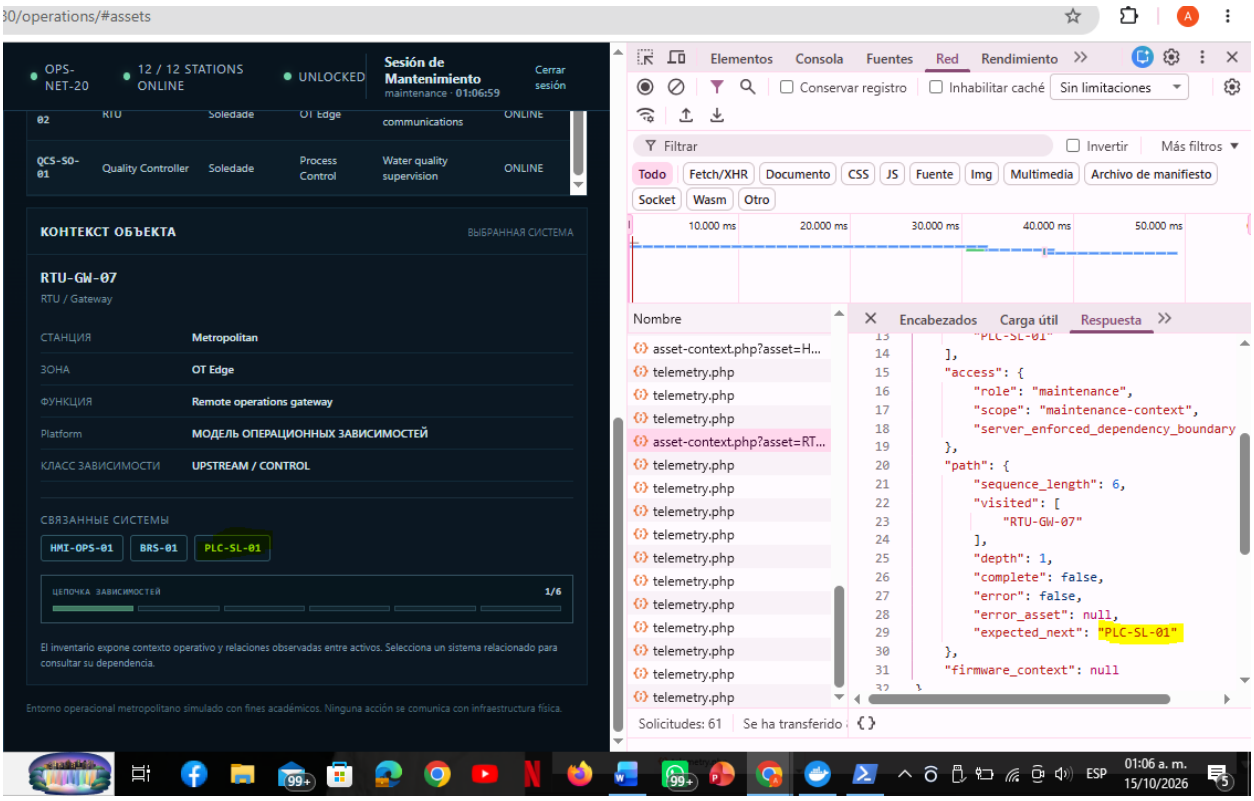
privilegios / broken access control en la cadena). La causa raíz es la violación del principio de mínimo privilegio en perfiles técnicos.

Comprobación de los hallazgos:

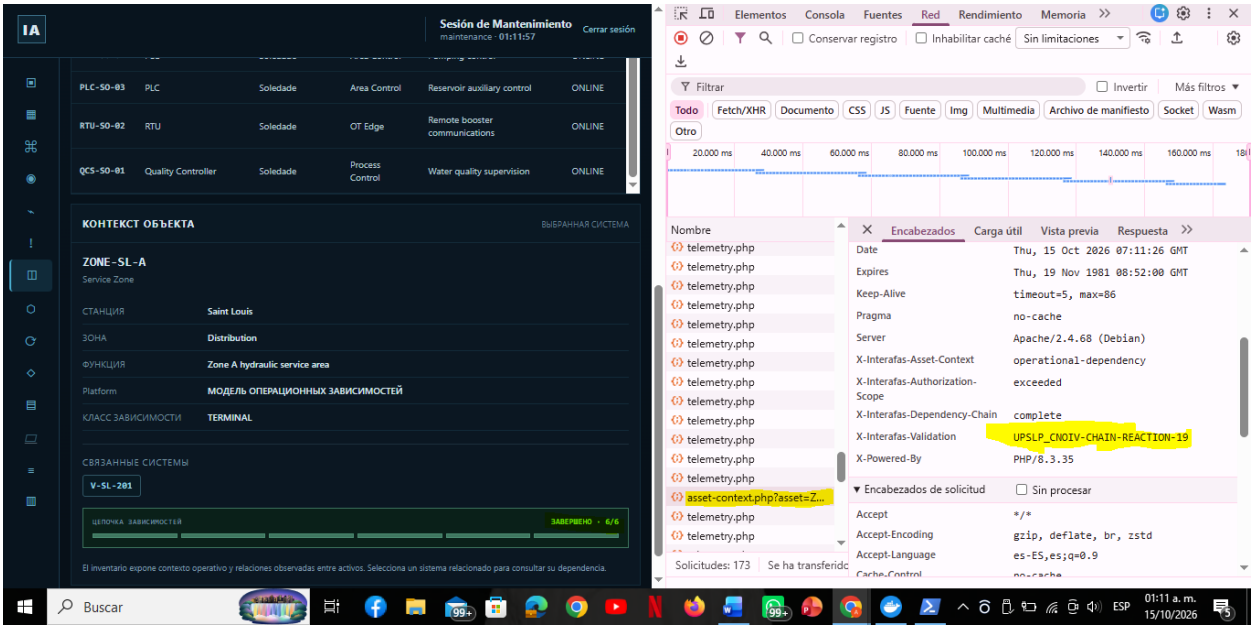
1. Se autenticó en el panel HMI utilizando un perfil de privilegios intermedios correspondiente al rol de mantenimiento (*maintenance*).
2. Se navegó hacia el módulo de gestión de activos físicos y lógicos (/operations/#assets), seleccionando el nodo central de la unidad de control (RTU-GW-07).
3. Aprovechando el exceso de privilegios del rol, se recorrió de manera secuencial la cadena de dependencias del sistema a través de peticiones al endpoint asset-context.php.
4. Se completaron exitosamente los 6 saltos lógicos requeridos por la topología industrial simulada (comunicaciones -> control -> proceso -> distribución de campo -> zona de servicio), validando el encadenamiento completo y obteniendo la cabecera de confirmación.

Evidencia técnica:

Secuencia completada: 6/6 saltos correctos en el indicador de dependencias.



Cabecera de respuesta con la bandera: UPSLP_CNOIV-CHAIN-REACTION-19



Impacto y riesgo:

Nivel de impacto: Alto

Confidencialidad e Integridad: Altas, demostrando que un atacante posicionado en un rol técnico estándar puede escalar lógicamente a través de toda la red de dependencias industriales sin requerir controles adicionales de reautenticación por eslabón.

Disponibilidad: Alta.

Un atacante que comprometa una cuenta de mantenimiento puede recorrer y manipular de forma fluida todos los eslabones de la infraestructura de control industrial desde el gateway hasta la válvula de campo final.

Mitigaciones:

Aplicar estrictamente el principio de mínimo privilegio, segmentando las capacidades operativas de las cuentas de mantenimiento para que solo puedan interactuar con los componentes estrictamente asignados a su ámbito de labor.

Reto 20: Impacto operacional completo en automatización simulada (la bandera final)

Descripción técnica y causa raíz:

La falta de validación de rangos y límites operacionales (Safety Bounds) en los scripts de control del HMI permite que parámetros críticos enviados mediante peticiones JSON sean modificados arbitrariamente (por ejemplo, introduciendo valores extremos como 99.9 en variables de calidad o presión), provocando fallas masivas en la simulación de

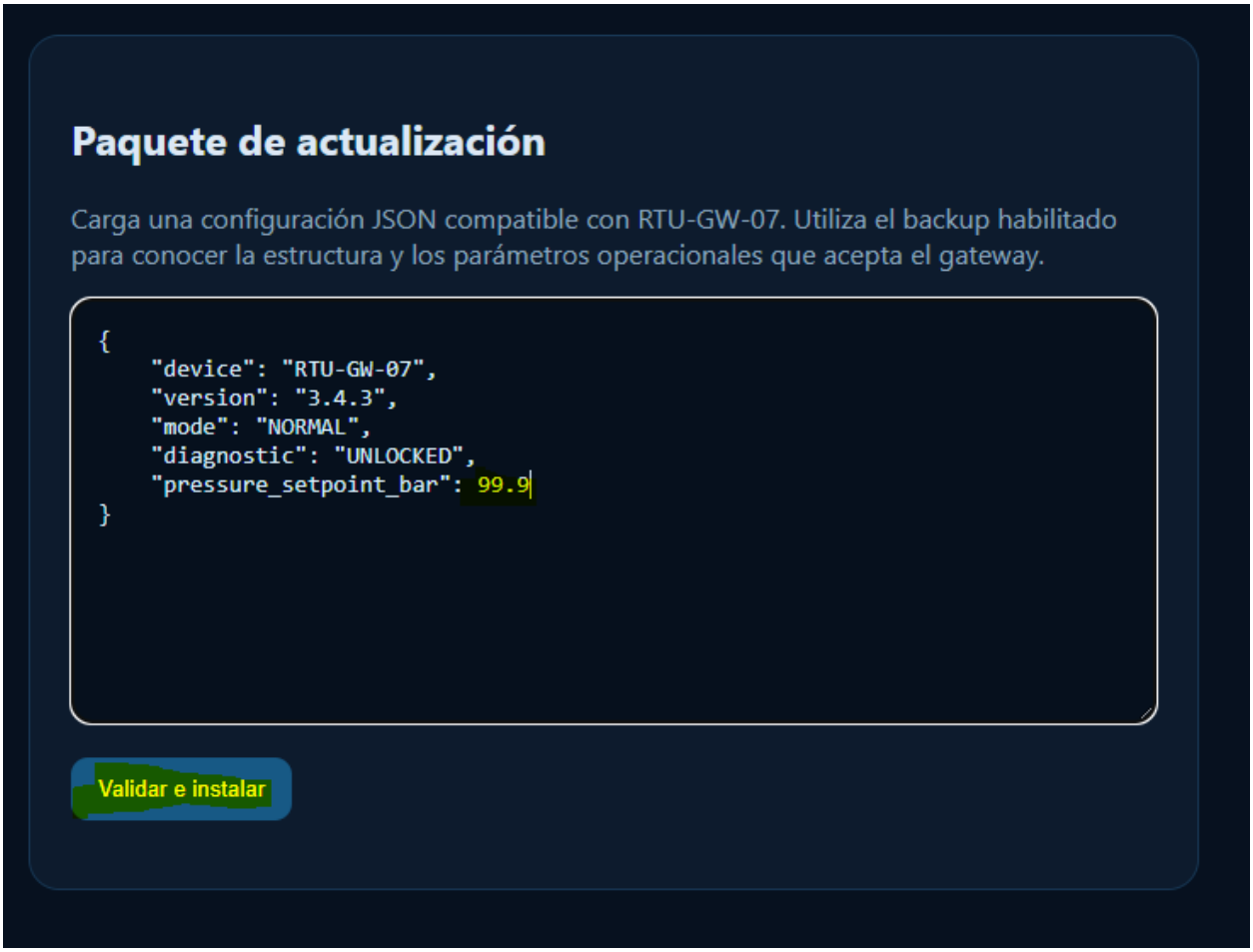
procesos. La causa raíz es la ausencia de validación lógica de seguridad industrial en el procesamiento de comandos HMI.

Comprobación de los hallazgos:

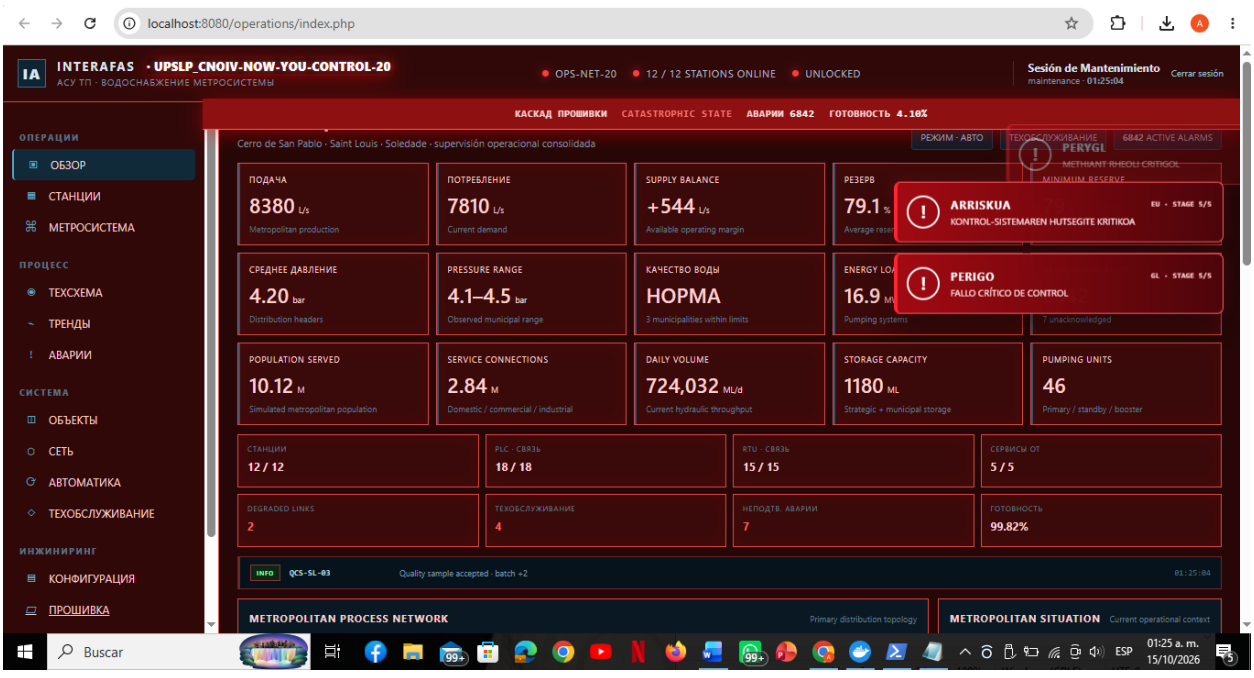
1. Tras haber vulnerado las capas de red, autenticación y gestión de firmware, se accedió al módulo de configuración de parámetros del sistema en el Centro de Operaciones.
2. Se identificó la ausencia total de validaciones lógicas de límites físicos y rangos operativos seguros (*Safety Bounds* o *Interlocks*) en el procesamiento de comandos del HMI.
3. Se inyectaron intencionalmente valores numéricos extremos y fuera de norma (como asignar una presión de 99.9 bar en los setpoints de distribución hidráulica) a través de peticiones de control JSON.
4. El sistema aceptó los comandos, alterando drásticamente el comportamiento de los procesos simulados y generando un estado masivo de alarmas críticas y fallas operacionales en toda la planta, validando el control absoluto del entorno y liberando la bandera final del ejercicio.

Evidencia técnica:

Alteración exitosa de parámetros en el flujo de telemetría y control.



Bandera final obtenida: UPSLP_CNOIV-NOW-YOU-CONTROL-20



Impacto y riesgo:

Nivel de impacto: Crítico

Confidencialidad: Alta.

Integridad y Disponibilidad: Críticas, representando un escenario de desastre operacional con daños físicos reales o simulados a la infraestructura crítica, interrupción generalizada del suministro de servicios esenciales a la población y pérdida total del control industrial.

Mitigaciones:

Implementar capas de validación de límites físicos (Safety Interlocks) tanto a nivel de software HMI como en el firmware de los PLCs y RTUs, impidiendo la aceptación de comandos que superen los rangos operativos seguros establecidos.

Cadena de ataque consolidada

Fase 1: Reconocimiento y exposición inicial

Reto 01: Lectura de /robots.txt y descarga de paquete .zip con credenciales (.env)

Reto 02: Extracción de versiones y rutas internas en manifiesto de compilación JS.

Reto 04: Recuperación de código fuente plano mediante archivos de respaldo (.bak).

Esta información obtenida alimenta la fase web.

Fase 2: Escalamiento y extracción de datos web

Reto 03 / Reto 12: Explotación de IDOR / BOLA para lectura de expedientes e historiales ajenos.

Reto 05 / Reto 15: Divulgación de arquitectura, rutas absolutas y esquemas de base de datos.

Reto 06: Escalamiento vertical de privilegios mediante manipulación de cookie de rol.

Reto 07 / Reto 08 / Reto 10: Inyección SQL ciega (Blind Boolean), Stored XSS y reutilización de sesión.

Con esto se logro el acceso inicial consolidado a través del portal web

Fase 3: Transición y salto de frontera ITI-OT

Reto 15: Identificación de la zona de red industrial (OPS-NET-20 / 10.40.20.0/24)

Reto 16: Suplantación de origen (*IP Spoofing*) mediante inyección del encabezado `X-Forwarded-For` para burlar el gateway operacional.

Acceso logrado al segmento operacional protegido

Fase 4: Compromiso del centro de operaciones y automatización (OT)

Reto 17: Acceso directo no autenticado a los servicios de telemetría industrial en tiempo real.

Reto 18: Recuperación de credenciales por fuerza bruta (*Hashcat*) sobre hashes SHA-1 heredados e instalación de firmware no verificado.

Reto 19: Encadenamiento de dependencias operacionales mediante el rol de mantenimiento.

Reto 20: Control total del proceso industrial automatizado y obtención de la bandera final (`UPSLP_CNOIV-NOW-YOU-CONTROL-20`).